

## Annex 4

---

# Instal·lació - Configuració **pfSense**

---



*Lluc Sánchez, Dani Ruiz  
2n ASIX - 25/26  
Projecte Intermodular - M0379*

# Índex

|                                                                         |           |
|-------------------------------------------------------------------------|-----------|
| <b>Instal·lació i Configuració Bàsica</b>                               | <b>1</b>  |
| 1. Preparació Màquina Virtual                                           | 1         |
| 2. Instal·lació pfSense                                                 | 2         |
| 3. Configuració pfSense                                                 | 4         |
| 4. Instal·lació Suricata                                                | 7         |
| 5. Configuració Inicial Suricata                                        | 10        |
| - Xarxa LAN                                                             | 10        |
| - Xarxa WAN                                                             | 11        |
| 6. Integració a la infraestructura existent                             | 12        |
| - Diagrama Gràfic                                                       | 12        |
| - Configuració pfSense Forwarder                                        | 13        |
| <b>Definició de Polítiques de Seguretat</b>                             | <b>15</b> |
| 1. Regles i signatures per a la detecció i prevenció                    | 15        |
| - Paquet Estàndard i Gratuït                                            | 15        |
| - Regles Personalitzades                                                | 16        |
| 2. Polítiques específiques per zones de la xarxa                        | 19        |
| - WAN                                                                   | 19        |
| - LAN                                                                   | 20        |
| 3. Establiment del mecanisme de respostes contra incidents              | 0         |
| <b>Anàlisi de Logs i Alertes</b>                                        | <b>0</b>  |
| 1. Configuració del sistema de logs detallats                           | 0         |
| - EVE JSON                                                              | 0         |
| - Logs Mgmt                                                             | 0         |
| 2. Implementació d'un sistema d'alerta temprana contra amenaces         | 0         |
| - Telegram                                                              | 0         |
| - pfSense                                                               | 0         |
| - Dashboard                                                             | 0         |
| 3. Estudi de casos pràctics basats en activitat real                    | 0         |
| - Log d'Atac DDoS (LAN)                                                 | 0         |
| - Log d'Intent de Descàrrega d'Arxiu .exe (LAN)                         | 0         |
| - Log Escaneig al port 3306 (WAN)                                       | 0         |
| <b>Simulació d'Atacs i Resposta</b>                                     | <b>0</b>  |
| 1. Simulació d'atacs específics per a comprovar l'eficàcia del sistema. | 0         |
| - WAN                                                                   | 0         |
| - LAN                                                                   | 0         |
| 2. Desenvolupament d'un pla de resposta a incidents                     | 0         |
| - Fase de Preparació                                                    | 0         |
| - Fase d'Identificació i Anàlisi                                        | 0         |
| - Fase de Contenció                                                     | 0         |
| - Fase d'Eliminació                                                     | 0         |
| - Fase de Recuperació                                                   | 0         |

|                                                                         |          |
|-------------------------------------------------------------------------|----------|
| - Fase de Millora                                                       | 0        |
| 3. Anàlisi i millora de la resposta a situacions crítiques              | 0        |
| - Anàlisi Profund                                                       | 0        |
| - Precisió de les Regles                                                | 0        |
| - Efectivitat de la comunicació                                         | 0        |
| <b>Configuració de Sistemes Complementaris</b>                          | <b>0</b> |
| 1. Integració amb sistemes de firewall i antivirus                      | 0        |
| - pfBlockerNG                                                           | 0        |
| 2. Configuració de connexions segures (VPN) i altres capes de seguretat | 0        |
| - WireGuard                                                             | 0        |
| - GeoIP Blocking                                                        | 0        |
| - Configuracions de Seguretat Extres                                    | 0        |
| 3. Optimització del rendiment del sistema IDS/IPS                       | 0        |

## Instal·lació i Configuració Bàsica

### 1. Preparació Màquina Virtual

Primer, amb la ISO del pfSense instal·lada, creem una nova màquina virtual Linux.

The screenshot shows the 'Nombre y sistema operativo' (Name and operating system) configuration window. The 'Nombre' (Name) is 'PROJ-pfSense'. The 'Carpeta' (Folder) is 'C:\Users\druiz\VirtualBox VMs'. The 'Imagen ISO' (ISO image) is 'C:\Users\druiz\Documents\maquinas virtuales\pfSense-CE-2.7.2-RELEASE-amd64.iso'. The 'Tipo' (Type) is 'Linux', 'Subtype' is 'Oracle Linux', and 'Versión' (Version) is 'Oracle Linux (64-bit)'. There is a checkbox for 'Omitir instalación desatendida' (Unattended installation) which is unchecked. At the bottom, there are three expandable sections: 'Instalación desatendida', 'Hardware', and 'Disco duro'.

Li indico els recursos que utilitzarà i la mida del disc dur, amb 30GB tenim de sobres.

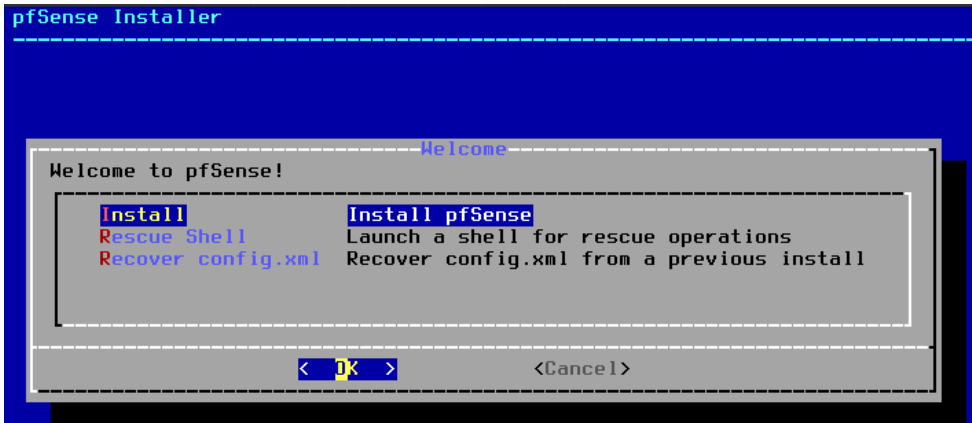
The screenshot shows two configuration windows. The top window is 'Hardware', showing 'Memoria base' (Base memory) set to 4096 MB and 'Procesadores' (Processors) set to 2. The bottom window is 'Disco duro' (Hard disk), showing the option to 'Crear un disco duro virtual ahora' (Create a new virtual hard disk now). The 'Ubicación y tamaño del archivo de disco' (Location and size of the disk file) is set to 'C:\Users\druiz\VirtualBox VMs\PROJ-pfSense\PROJ-pfSense.vdi' with a size of 30,00 GB. The 'Tipo y variante de archivo de disco duro' (Type and variant of the hard disk file) is set to 'VDI (VirtualBox Disk Image)' with the option 'Reservar completamente' (Allocate all space now) selected.

A les interfícies de xarxa, li dono bridge per descarregar els paquets que contenen les firmes i per veure el pfSense des de la meua màquina real, també li afegueixo un adaptador host only per connectar-lo a la xarxa local on es situen les altres màquines. Farem que totes les màquines de la xarxa host only passin pel pfSense per sortir a la xarxa WAN.

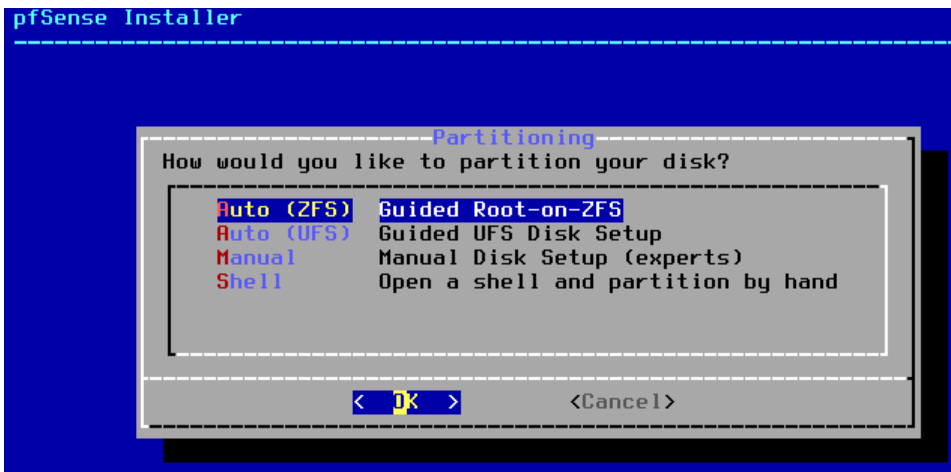


## 2. Instal·lació pfSense

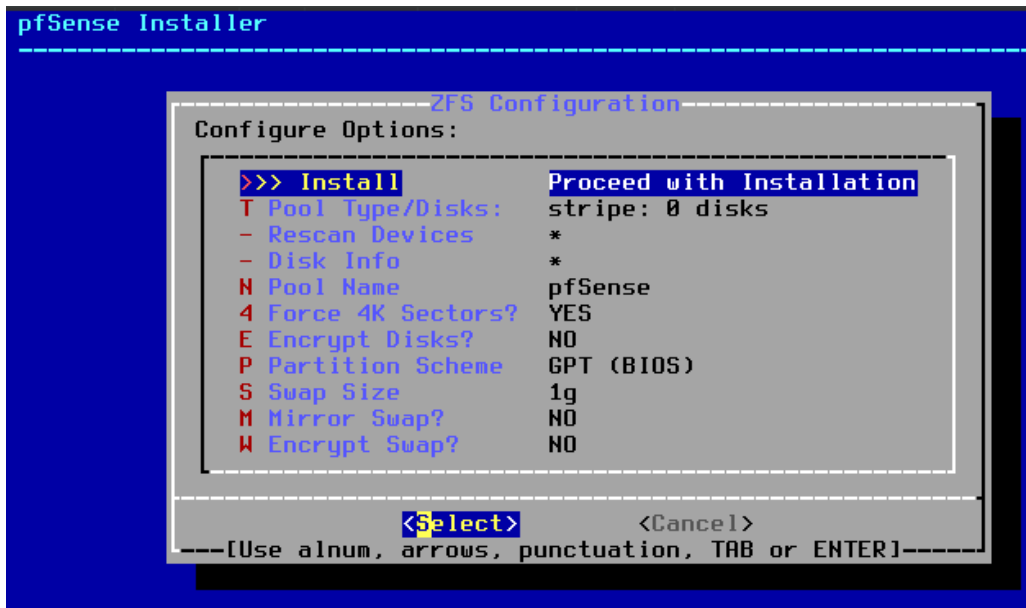
Una vegada iniciat, instal·lem pfsense.



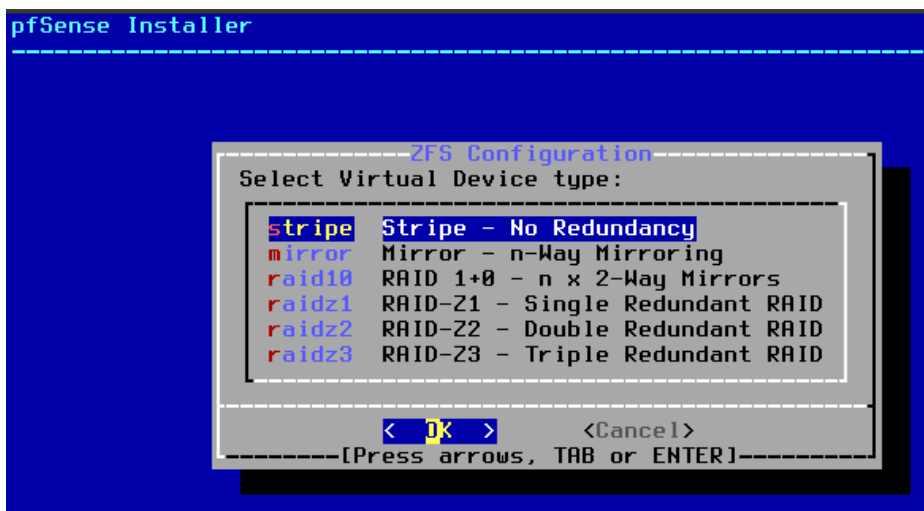
Particions del disc, Auto (ZFS).



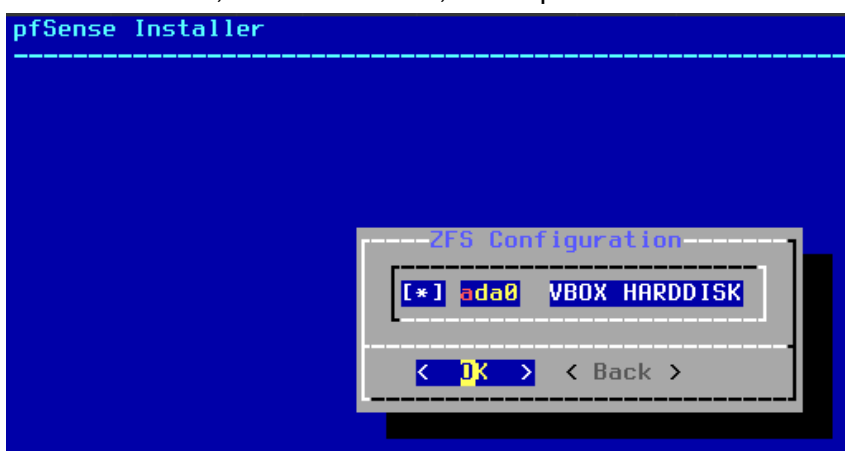
Prenem instal·lar, no toquem cap opció.



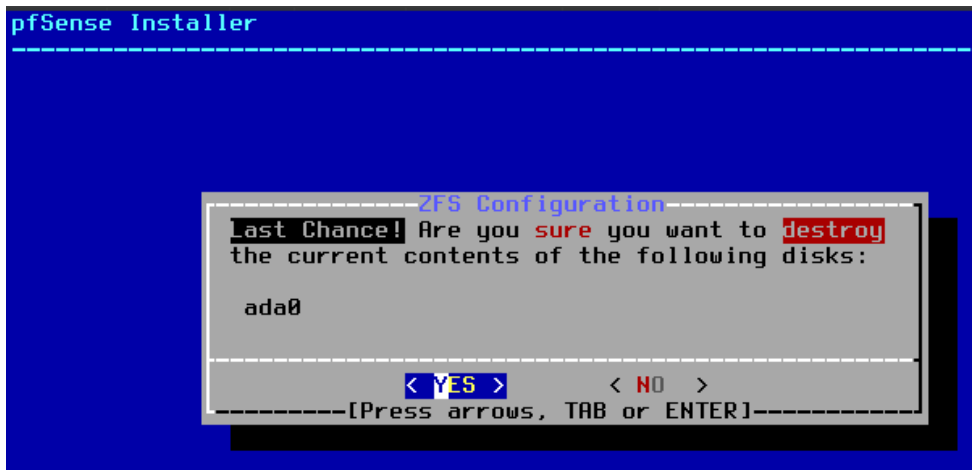
Seleccionem Stripe, no necessitem redundància a les dades.



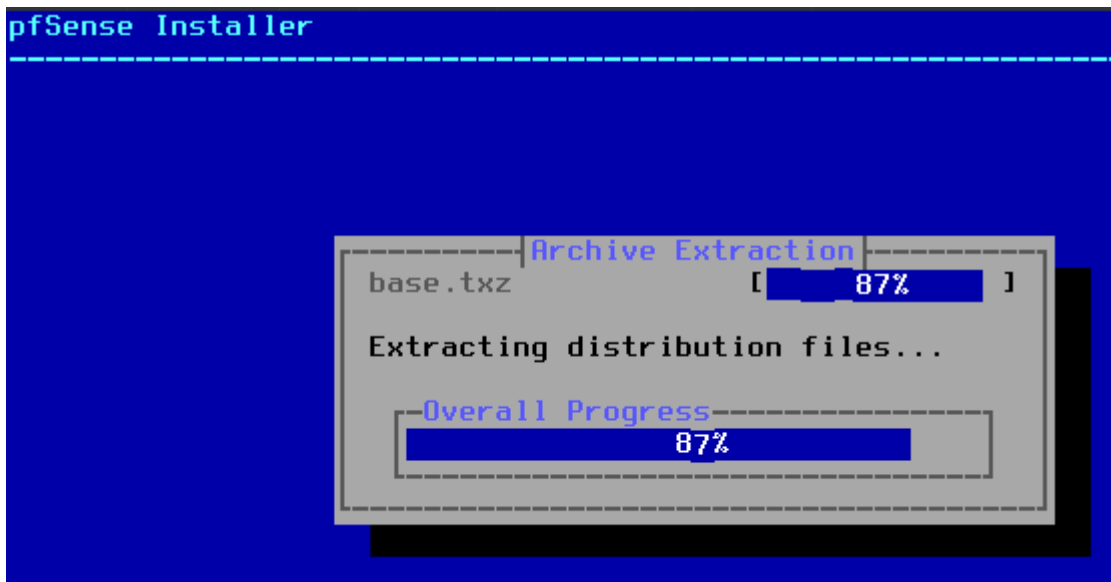
I escollim el disc, en el nostre cas, l'únic que tenim.



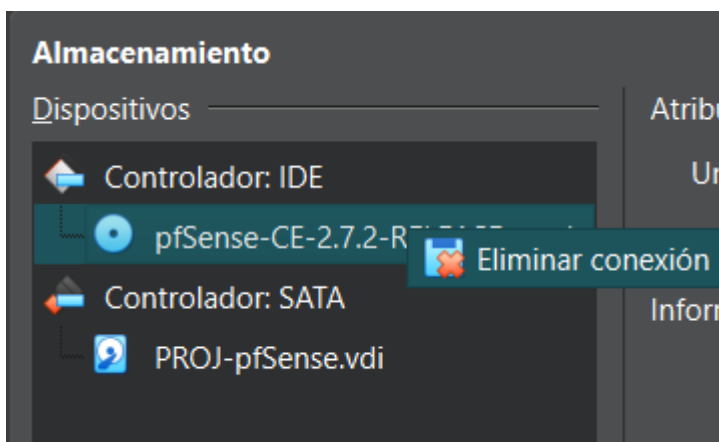
Apliquem el format nou al disc.



Esperem que finalitzi i reiniciem la màquina.



Traiem la ISO i tornem a iniciar.



### 3. Configuració pfSense

Una vegada ens trobem dintre, editem la IP de les interfícies de xarxa, opció 2.

```
FreeBSD/amd64 (pfSense.home.arp) (ttyv0)
KVM Guest - Netgate Device ID: 211994463d9a1de8c1d8
*** Welcome to pfSense 2.7.2-RELEASE (amd64) on pfSense ***

WAN (wan)      -> em0      -> v4/DHCP4: 10.93.255.94/16
LAN (lan)      -> em1      -> v4: 192.168.20.100/24

0) Logout (SSH only)          9) pfTop
1) Assign Interfaces          10) Filter Logs
2) Set interface(s) IP address 11) Restart webConfigurator
3) Reset webConfigurator password 12) PHP shell + pfSense tools
4) Reset to factory defaults  13) Update from console
5) Reboot system              14) Enable Secure Shell (sshd)
6) Halt system                15) Restore recent configuration
7) Ping host                  16) Restart PHP-FPM
8) Shell

Enter an option: 2
```

2 una altra vegada per editar la segona interfície.

```
Available interfaces:

1 - WAN (em0 - dhcp, dhcp6)
2 - LAN (em1 - static)

Enter the number of the interface you wish to configure: 2
```

Responem a les preguntes que ens fa, no volem que obtingui la IP per DHCP, li indiquem que la IP serà la 192.168.20.100/24, no volem DHCP6 ni IPv6

```
Configure IPv4 address LAN interface via DHCP? (y/n) n
Enter the new LAN IPv4 address. Press <ENTER> for none:
> 192.168.20.100

Subnet masks are entered as bit counts (as in CIDR notation) in pfSense.
e.g. 255.255.255.0 = 24
     255.255.0.0   = 16
     255.0.0.0     = 8

Enter the new LAN IPv4 subnet bit count (1 to 32):
> 24

For a WAN, enter the new LAN IPv4 upstream gateway address.
For a LAN, press <ENTER> for none:
>

Configure IPv6 address LAN interface via DHCP6? (y/n) n
Enter the new LAN IPv6 address. Press <ENTER> for none:
>

Do you want to enable the DHCP server on LAN? (y/n) n
```

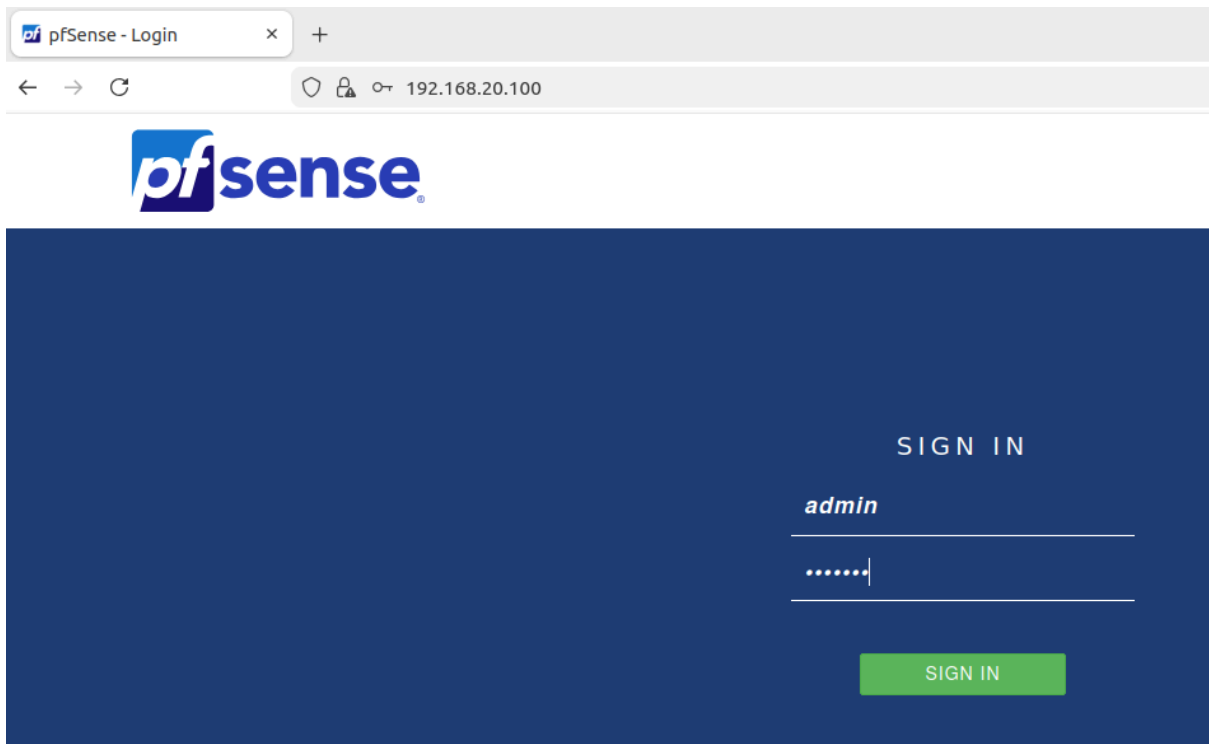
Tampoc volem revertir a HTTP ja que la connexió no seria segura i a l'hora d'iniciar sessió les credencials viatjarien per la xarxa en text pla. Per accedir al lloc web de pfSense hem d'inserir al navegador la IP que acabem d'assignar.



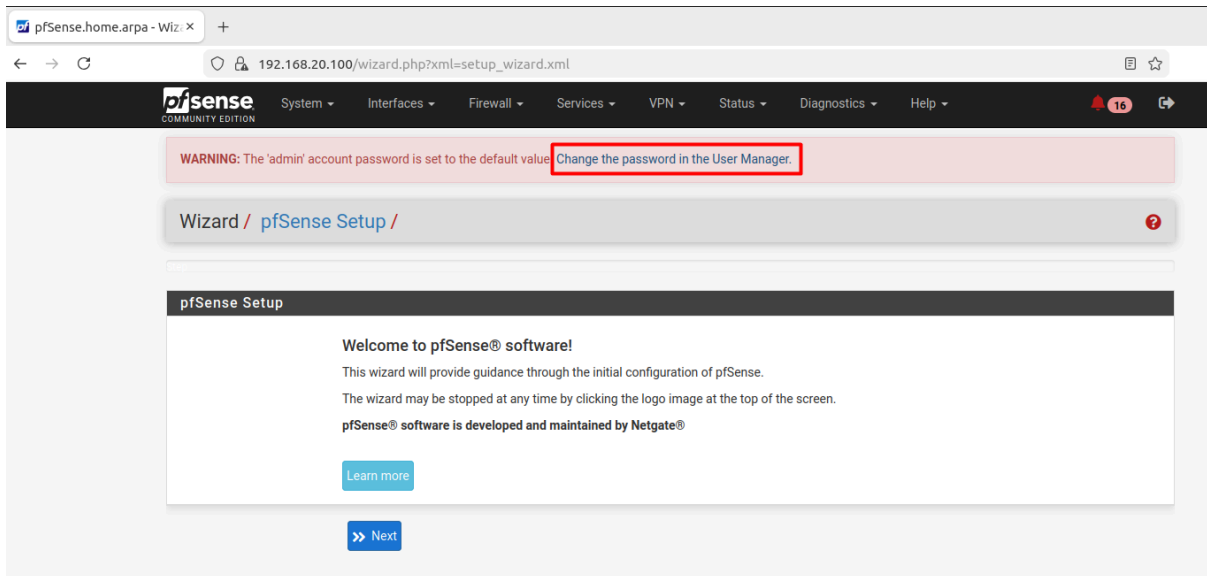
```
Do you want to revert to HTTP as the webConfigurator protocol? (y/n) n
Please wait while the changes are saved to LAN...
Reloading filter...
Reloading routing configuration...
DHCPD...

The IPv4 LAN address has been set to 192.168.20.100/24
You can now access the webConfigurator by opening the following URL in your web
browser:
    https://192.168.20.100/
```

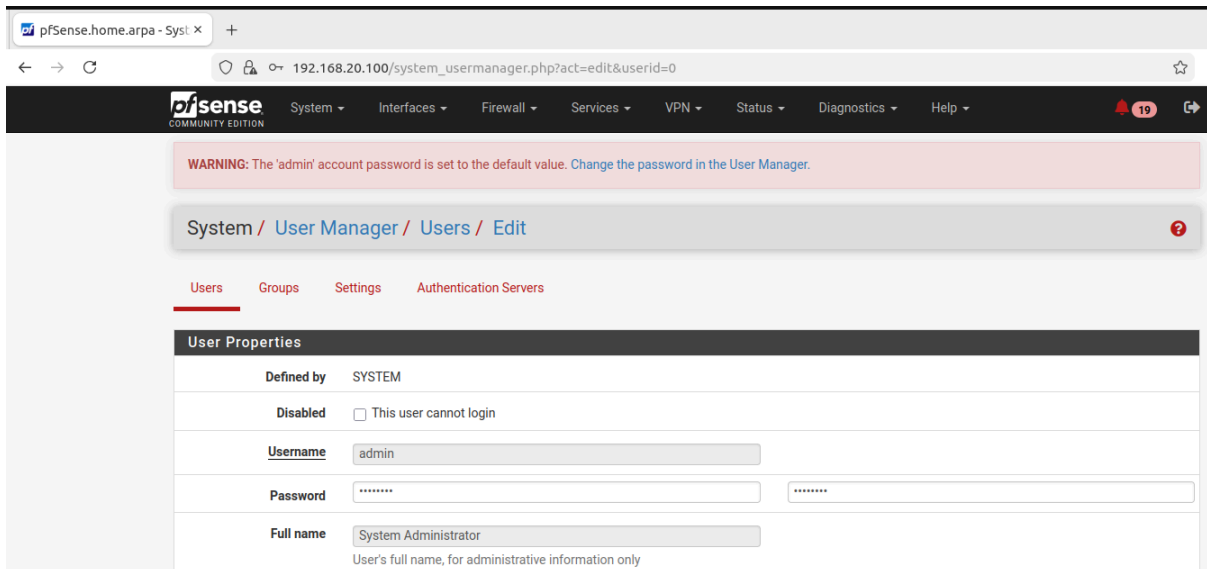
Ara, des d'un client que es trobi a la mateixa xarxa LAN del pfSense, escrivim al navegador <https://192.168.20.100>. Introduïm usuari admin i contrasenya pfsense per accedir al menú principal.



El primer que farem serà modificar la contrasenya d'administrador, ja que ara mateix tenim la predeterminada.



Guardem la nova contrasenya.

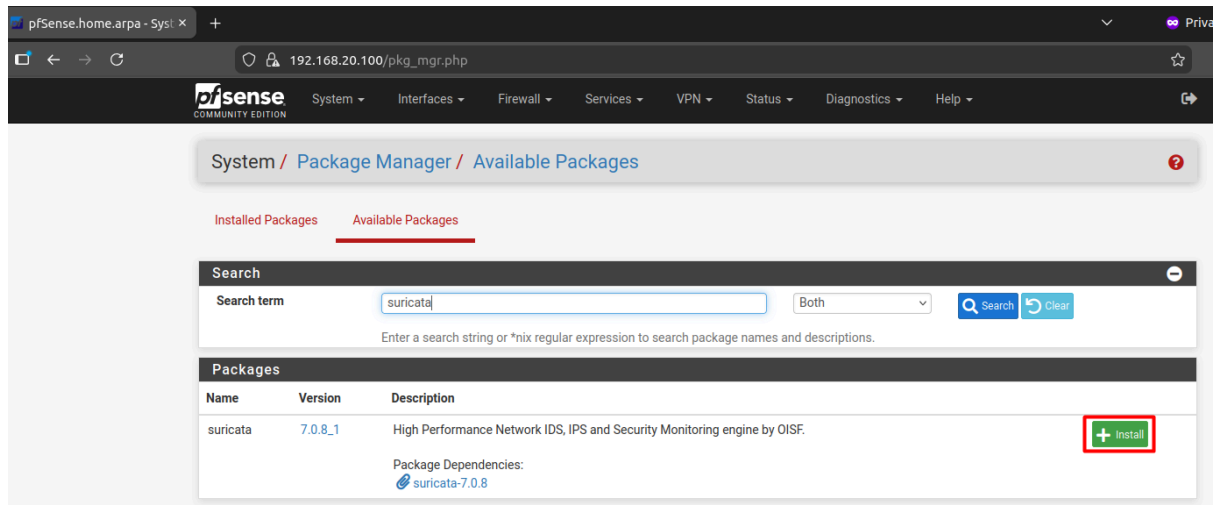


#### 4. Instal·lació Suricata

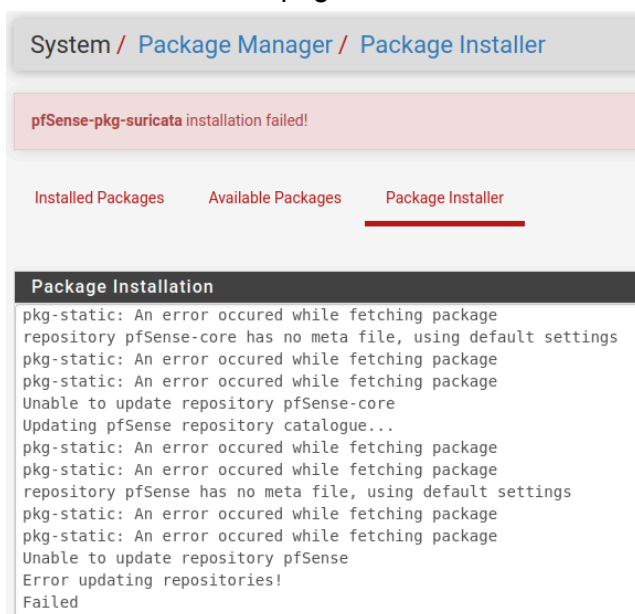
Quan intentem buscar algun servei a Package Manager, ens apareix que no pot trobar cap paquet disponible, llavors trobem que potser cal fer un update i upgrade al pfsense.

```
[2.7.2-RELEASE][root@pfSense.home.arpal/root]: pkg-static update -f
Updating pfSense-core repository catalogue...
pkg-static: An error occurred while fetching package
Fetching meta.txz: 100% 916 B 0.9kB/s 00:01
Fetching packagesite.pkg: 100% 1 KiB 1.5kB/s 00:01
Processing entries: 100%
pfSense-core repository update completed. 4 packages processed.
Updating pfSense repository catalogue...
Fetching meta.conf: 100% 179 B 0.2kB/s 00:01
Fetching packagesite.pkg: 100% 192 KiB 7.3kB/s 00:27
Processing entries: 100%
pfSense repository update completed. 550 packages processed.
All repositories are up to date.
[2.7.2-RELEASE][root@pfSense.home.arpal/root]: pkg-static upgrade
Updating pfSense-core repository catalogue...
```

Una vegada actualitzat, anem a System → Package Manager → Available Package, busquem Suricata i l'instal·lem.



Però finalment no he pogut, m'ha donat un error durant la instal·lació.



Llavors he provat d'instal·lar-lo utilitzant la comanda pkg-static install pfSense-pkg-suricata des del terminal de pfSense.

```
[2.7.2-RELEASE][root@pfSense.home.arpal]/root: pkg-static install pfSense-pkg-suricata
```

```
Number of packages to be installed: 14

The process will require 57 MiB more space.
11 MiB to be downloaded.

Proceed with this action? [y/N]: y
[1/14] Fetching libyaml-0.2.5.pkg: 100% 76 KiB 3.5kB/s 00:22
[2/14] Fetching nss-3.93.pkg: 100% 2 MiB 58.5kB/s 00:38
[3/14] Fetching pfSense-pkg-suricata-7.0.8_1.pkg: 91% 144 KiB 147.0kB/s 00:01
[3/14] Fetching pfSense-pkg-suricata-7.0.8_1.pkg: 100% 157 KiB 160.5kB/s 00:01
[4/14] Fetching py311-setuptools-63.1.0_1.pkg: 13% 192 KiB 196.2kB/s 00:06
[4/14] Fetching py311-setuptools-63.1.0_1.pkg: 17% 256 KiB 65.5kB/s 00:06
[4/14] Fetching py311-setuptools-63.1.0_1.pkg: 21% 304 KiB 49.2kB/s 00:07
[4/14] Fetching py311-setuptools-63.1.0_1.pkg: 30% 432 KiB 131.1kB/s 00:06
[4/14] Fetching py311-setuptools-63.1.0_1.pkg: 33% 480 KiB 49.2kB/s 00:07
[4/14] Fetching py311-setuptools-63.1.0_1.pkg: 54% 784 KiB 311.3kB/s 00:04
[4/14] Fetching py311-setuptools-63.1.0_1.pkg: 77% 1 MiB 344.1kB/s 00:01
[4/14] Fetching py311-setuptools-63.1.0_1.pkg: 86% 1 MiB 131.1kB/s 00:01
[4/14] Fetching py311-setuptools-63.1.0_1.pkg: 100% 1 MiB 70.0kB/s 00:21
[5/14] Fetching libpcap-1.10.4.pkg: 100% 295 KiB 302.5kB/s 00:01
[6/14] Fetching nspr-4.35.pkg: 100% 261 KiB 267.1kB/s 00:01
[7/14] Fetching py311-yaml-6.0.pkg: 100% 177 KiB 181.5kB/s 00:01
[8/14] Fetching jansson-2.14.pkg: 100% 50 KiB 50.9kB/s 00:01
[9/14] Fetching hyperscan-5.4.0.pkg: 100% 3 MiB 282.2kB/s 00:11
[10/14] Fetching libpfctl-0.8.pkg: 100% 16 KiB 16.4kB/s 00:01
[11/14] Fetching libnet-1.2.1.pkg: 100% 92 KiB 94.2kB/s 00:01
[12/14] Fetching suricata-7.0.8.pkg: 100% 3 MiB 199.9kB/s 00:18
[13/14] Fetching libmaxminddb-1.7.1_1.pkg: 100% 38 KiB 38.7kB/s 00:01
[14/14] Fetching hiredis-1.0.2.pkg: 100% 143 KiB 146.9kB/s 00:01
Checking integrity... done (0 conflicting)
```

Ara ja el trobem als paquets instal·lats.

System / Package Manager / Installed Packages

Installed Packages Available Packages

| Name       | Category | Version | Description                                                               | Actions |
|------------|----------|---------|---------------------------------------------------------------------------|---------|
| ✓ suricata | security | 7.0.8_1 | High Performance Network IDS, IPS and Security Monitoring engine by OISF. |         |

Package Dependencies:  
suricata-7.0.8

= Update = Current  
 = Remove = Information = Reinstall

Newer version available

Package is configured but not (fully) installed or deprecated

També apareix a l'apartat de serveis.

Services / Suricata

Interfaces Global Settings Updates Alerts Blocks Files Pass Lists Suppress Logs View Logs Mgmt SID Mgmt

Sync IP Lists

| Interface | Suricata Status | Pattern Match | Blocking Mode | Description | Actions |
|-----------|-----------------|---------------|---------------|-------------|---------|
|-----------|-----------------|---------------|---------------|-------------|---------|

+ Add

## 5. Configuració Inicial Suricata

### - Xarxa LAN

Fem add per afegir la interfície de la xarxa LAN a Suricata.

The screenshot shows the 'LAN - Interface Settings' page in the Suricata configuration interface. The breadcrumb trail is 'Services / Suricata / LAN - Interface Settings'. The left sidebar has 'Interfaces' selected. The top navigation bar includes 'Interfaces', 'Global Settings', 'Updates', 'Alerts', 'Blocks', 'Files', 'Pass Lists', 'Suppress', 'Logs View', 'Logs Mgmt', and 'SID Mgmt'. Below this, there are sub-sections for 'Sync', 'IP Lists', and 'LAN Settings' (which is active). The 'General Settings' section contains three fields: 'Enable' (checked), 'Interface' (set to 'LAN (em1)'), and 'Description' (set to 'LAN').

192.168.20.100/suricata/suricata\_interfaces\_edit.php?id=0

pfSense COMMUNITY EDITION

System ▾ Interfaces ▾ Firewall ▾ Services ▾ VPN ▾ Status ▾ Diagnostics ▾ Help ▾

Services / Suricata / LAN - Interface Settings

Interfaces Global Settings Updates Alerts Blocks Files Pass Lists Suppress Logs View Logs Mgmt SID Mgmt

Sync IP Lists

LAN Settings LAN Categories LAN Rules LAN Flow/Stream LAN App Parsers LAN Variables LAN IP Rep

**General Settings**

**Enable** ☒ Checking this box enables Suricata inspection on the interface.

**Interface** LAN (em1) ▾  
Choose which interface this Suricata instance applies to. In most cases, you will want to choose LAN here if this is the first Suricata-configured interface.

**Description** LAN  
Enter a meaningful description here for your reference. The default is the pfSense interface friendly description.

Més avall, activem Send Alerts to System, per permetre a Suricata envia alertes i que es guardin als logs.

The screenshot shows the 'Logging Settings' page. The 'Send Alerts to System Log' checkbox is checked. Below it, a note states: 'NOTE: the FreeBSD syslog daemon will automatically truncate exported messages to 480 bytes max.' The 'Log Facility' is set to 'LOCAL1' and the 'Log Priority' is set to 'NOTICE'.

**Logging Settings**

**Send Alerts to System Log** ☒ Suricata will send Alerts from this interface to the firewall's system log.  
NOTE: the FreeBSD syslog daemon will automatically truncate exported messages to 480 bytes max.

**Log Facility** LOCAL1 ▾  
Select system log Facility to use for reporting. Default is LOCAL1.

**Log Priority** NOTICE ▾  
Select system log Priority (Level) to use for reporting. Default is NOTICE.

Farem una petita prova iniciant el servei Suricata per aquesta interfície, a veure si s'encén correctament.

The screenshot shows the 'Interface Settings Overview' table. The table has columns for 'Interface', 'Suricata Status', 'Pattern Match', 'Blocking Mode', 'Description', and 'Actions'. The first row shows 'LAN (em1)' with a status of 'DISABLED' (indicated by a red 'x' icon) and a 'Start suricata on this interface' button. The 'Pattern Match' is 'AUTO' and the 'Blocking Mode' is 'DISABLED'. The 'Description' is 'LAN'. The 'Actions' column contains icons for edit, add, and delete.

192.168.20.100/suricata/suricata\_interfaces.php

pfSense COMMUNITY EDITION

System ▾ Interfaces ▾ Firewall ▾ Services ▾ VPN ▾ Status ▾ Diagnostics ▾ Help ▾

Services / Suricata

Interfaces Global Settings Updates Alerts Blocks Files Pass Lists Suppress Logs View Logs Mgmt SID Mgmt

Sync IP Lists

**Interface Settings Overview**

| Interface | Suricata Status | Pattern Match | Blocking Mode | Description | Actions |
|-----------|-----------------|---------------|---------------|-------------|---------|
| LAN (em1) |                 | AUTO          | DISABLED      | LAN         |         |

Start suricata on this interface

+ Add - Delete

Sense errors.

192.168.20.100/suricata/suricata\_interfaces.php

pfSense COMMUNITY EDITION

System ▾ Interfaces ▾ Firewall ▾ Services ▾ VPN ▾ Status ▾ Diagnostics ▾ Help ▾

Services / Suricata

Interfaces Global Settings Updates Alerts Blocks Files Pass Lists Suppress Logs View Logs Mgmt SID Mgmt

Sync IP Lists

Interface Settings Overview

| Interface | Suricata Status | Pattern Match | Blocking Mode | Description | Actions |
|-----------|-----------------|---------------|---------------|-------------|---------|
| LAN (em1) |                 | AUTO          | DISABLED      | LAN         |         |

suricata is running on this interface

+ Add Delete

#### - Xarxa WAN

Ara ens toca afegir la interfície de xarxa que surt cap a internet i que dona connexió a tota la xarxa LAN, per això ens interessa tenir controlat tots els paquets que entren a la LAN per la WAN.

Tornem a Suricata i fem Add un altre cop.

192.168.20.100/suricata/suricata\_interfaces.php

pfSense COMMUNITY EDITION

System ▾ Interfaces ▾ Firewall ▾ Services ▾ VPN ▾ Status ▾ Diagnostics ▾ Help ▾

Services / Suricata

Interfaces Global Settings Updates Alerts Blocks Files Pass Lists Suppress Logs View Logs Mgmt SID Mgmt

Sync IP Lists

Interface Settings Overview

| Interface | Suricata Status | Pattern Match | Blocking Mode | Description | Actions |
|-----------|-----------------|---------------|---------------|-------------|---------|
| LAN (em1) |                 | AUTO          | DISABLED      | LAN         |         |

+ Add Delete

Com hem fet a la LAN, activem que Suricata envii alertes.

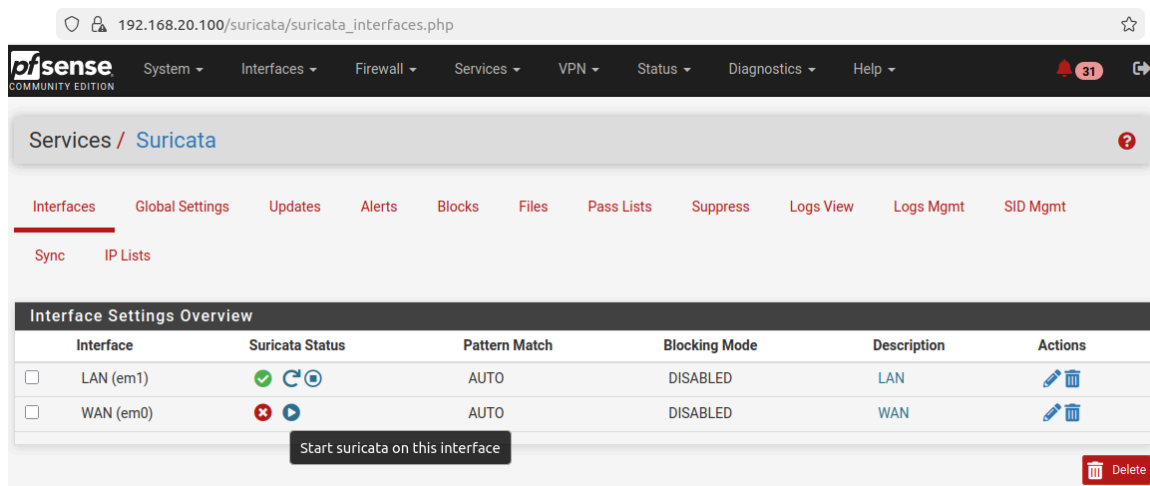
Logging Settings

Send Alerts to System Log ☒ Suricata will send Alerts from this interface to the firewall's system log.  
NOTE: the FreeBSD syslog daemon will automatically truncate exported messages to 480 bytes max.

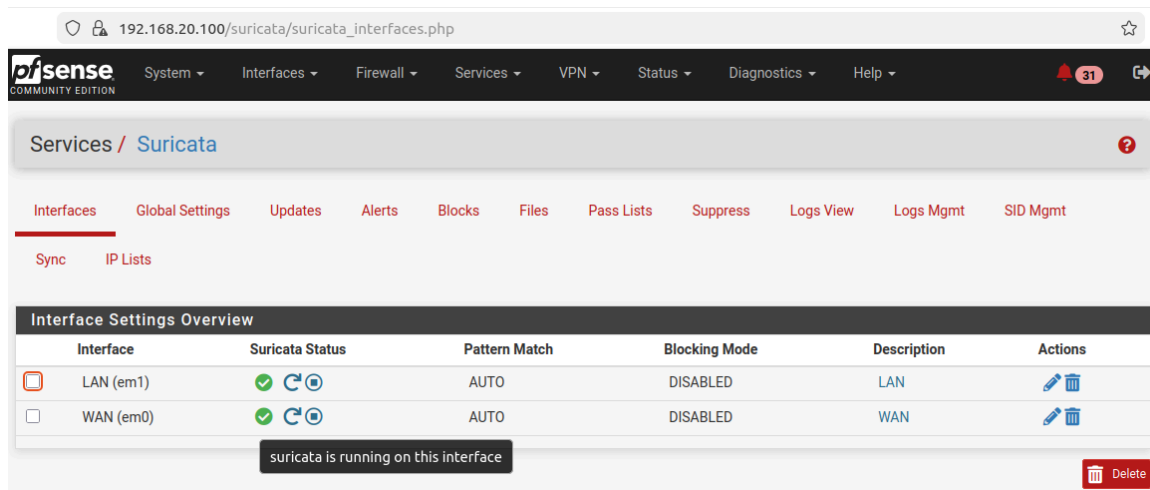
Log Facility LOCAL1  
Select system log Facility to use for reporting. Default is LOCAL1.

Log Priority NOTICE  
Select system log Priority (Level) to use for reporting. Default is NOTICE.

Guardem i provem d'encendre la interfície.



Cap problema.



## 6. Integració a la infraestructura existent

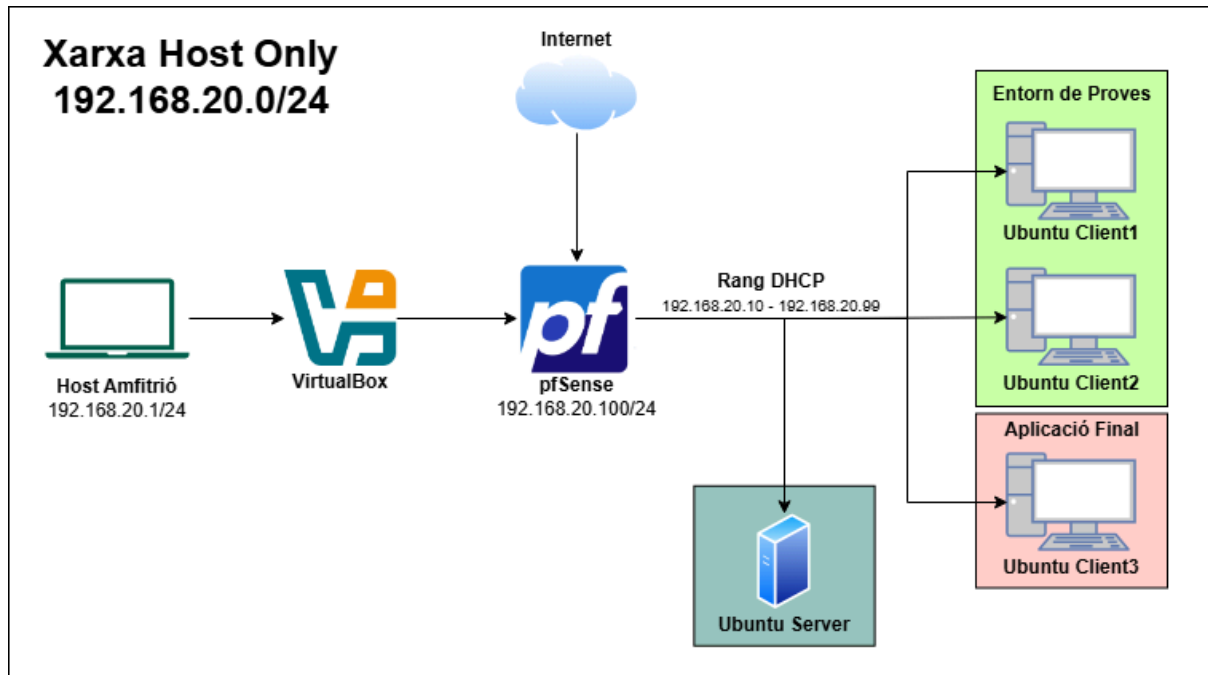
### - Diagrama Gràfic

pfSense actua com a gateway/firewall i configurarem Suricata perquè actuï contra les deteccions d'atacs que trobi.

A continuació es mostra el diagrama representatiu de la xarxa integrant el pfSense.

Integrarem pfSense en una xarxa ja existent, trobem 1 ubuntu server i uns quants clients (escalable en un futur), utilitzarem el Client3 per connectar-nos des del navegador a la interfície gràfica de pfSense, on realitzarem configuracions, creació de noves regles...

D'aquesta manera pfSense escoltarà la xarxa host only i s'encarregarà d'actuar contra les amenaces que trobi segons les regles que li configurem. Farem que el pfSense sigui l'enrutador de la xarxa LAN cap a la WAN, així podrem controlar el tràfic que entra d'internet cap a la nostra xarxa i el que surt.



#### - Configuració pfSense Forwarder

També aprofitarem per configurar el DHCP a pfSense, d'aquesta manera obtindrem la configuració de la xarxa automàticament als clients.

192.168.20.100/services\_dhcp.php

pfSense  
COMMUNITY EDITION

System ▾ Interfaces ▾ Firewall ▾ Services ▾ VPN ▾ Status ▾ Diagnostics ▾ Help ▾

Services / DHCP Server / LAN

ISC DHCP has reached end-of-life and will be removed in a future version of pfSense. Visit [System > Advanced > Networking](#) to switch DHCP backend.

LAN

**General DHCP Options**

|                           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|---------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| DHCP Backend              | ISC DHCP                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Enable                    | <input checked="" type="checkbox"/> Enable DHCP server on LAN interface                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| BOOTP                     | <input type="checkbox"/> Ignore BOOTP queries                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Deny Unknown Clients      | <input type="text" value="Allow all clients"/> <p>When set to <b>Allow all clients</b>, any DHCP client will get an IP address within this scope/range on this interface. If set to <b>Allow known clients from any interface</b>, any DHCP client with a MAC address listed in a static mapping on <b>any</b> scope(s)/interface(s) will get an IP address. If set to <b>Allow known clients from only this interface</b>, only MAC addresses listed in static mappings on this interface will get an IP address within this scope/range.</p> |
| Ignore Denied Clients     | <input type="checkbox"/> Ignore denied clients rather than reject<br>This option is not compatible with failover and cannot be enabled when a Failover Peer IP address is configured.                                                                                                                                                                                                                                                                                                                                                          |
| Ignore Client Identifiers | <input type="checkbox"/> Do not record a unique identifier (UID) in client lease data if present in the client DHCP request<br>This option may be useful when a client can dual boot using different client identifiers but the same hardware (MAC) address. Note that the resulting server behavior violates the official DHCP specification.                                                                                                                                                                                                 |

Especifiquem el rang d'IPs disponibles pel DHCP.



| Primary Address Pool                                                                                                    |                                                                                                                                                                 |
|-------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Subnet                                                                                                                  | 192.168.20.0/24                                                                                                                                                 |
| Subnet Range                                                                                                            | 192.168.20.1 - 192.168.20.254                                                                                                                                   |
| Address Pool Range                                                                                                      | <div>192.168.20.10</div> <div>From</div> <div>192.168.20.99</div> <div>To</div>                                                                                 |
| The specified range for this pool must not be within the range configured on any other address pool for this interface. |                                                                                                                                                                 |
| Additional Pools                                                                                                        | <div>+ Add Address Pool</div> <div>If additional pools of addresses are needed inside of this subnet outside the above range, they may be specified here.</div> |

Seguidament, accedim a DNS Resolver per activar el forwarding.

**DNS Query Forwarding** ☒ Enable Forwarding Mode  
If this option is set, DNS queries will be forwarded to the upstream DNS servers defined under [System > General Setup](#) or those obtained via dynamic interfaces such as DHCP, PPP, or OpenVPN (if DNS Server Override is enabled there).

Entrem a l'eina de DNS LookUp per verificar que tenim connexió a internet i el DNS resol correctament els noms de domini.

192.168.20.100/diag\_dns.php

System Interfaces Firewall Services VPN Status Diagnostics

Diagnostics / DNS Lookup

DNS Lookup

Hostname

Lookup

+ Add Alias

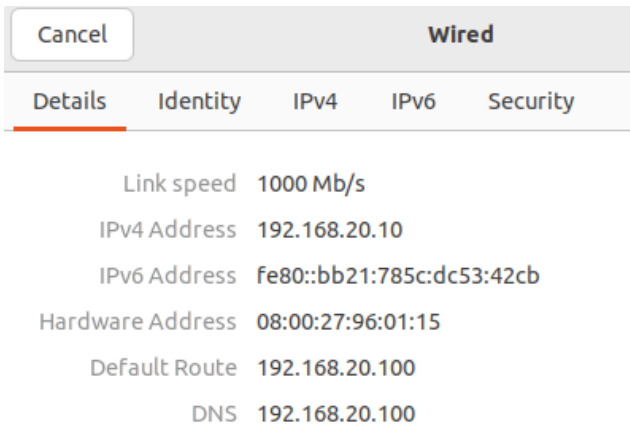
Results

| Result                   | Record type |
|--------------------------|-------------|
| 172.217.171.35           | A           |
| 2a00:1450:4003:80b::2003 | AAAA        |

Timings

| Name server | Query time |
|-------------|------------|
| 127.0.0.1   | 66 msec    |
| 10.93.0.1   | 7 msec     |

Als clients configurem tant l'IP com el DNS automàtic, a la captura es mostra els valors obtinguts.



Fem pings per confirmar.

```
alume@client3-danilluc:~$ ping 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data:
64 bytes from 8.8.8.8: icmp_seq=1 ttl=112 time=33.6 ms

64 bytes from 8.8.8.8: icmp_seq=2 ttl=112 time=23.9 ms
^C
--- 8.8.8.8 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1545ms
rtt min/avg/max/mdev = 23.871/28.739/33.608/4.868 ms
alume@client3-danilluc:~$ ping google.es
PING google.es (172.217.171.35) 56(84) bytes of data:
64 bytes from lcmdb-ac-in-f3.1e100.net (172.217.171.35): icmp_seq=1 ttl=112 time=20.3 ms
64 bytes from lcmdb-ac-in-f3.1e100.net (172.217.171.35): icmp_seq=2 ttl=112 time=20.0 ms
64 bytes from lcmdb-ac-in-f3.1e100.net (172.217.171.35): icmp_seq=3 ttl=112 time=21.5 ms
64 bytes from lcmdb-ac-in-f3.1e100.net (172.217.171.35): icmp_seq=4 ttl=112 time=28.1 ms
64 bytes from lcmdb-ac-in-f3.1e100.net (172.217.171.35): icmp_seq=5 ttl=112 time=20.4 ms
64 bytes from lcmdb-ac-in-f3.1e100.net (172.217.171.35): icmp_seq=6 ttl=112 time=30.3 ms
^C
--- google.es ping statistics ---
6 packets transmitted, 6 received, 0% packet loss, time 5091ms
rtt min/avg/max/mdev = 19.963/23.427/30.273/4.145 ms
```

Fem el mateix pel servidor.

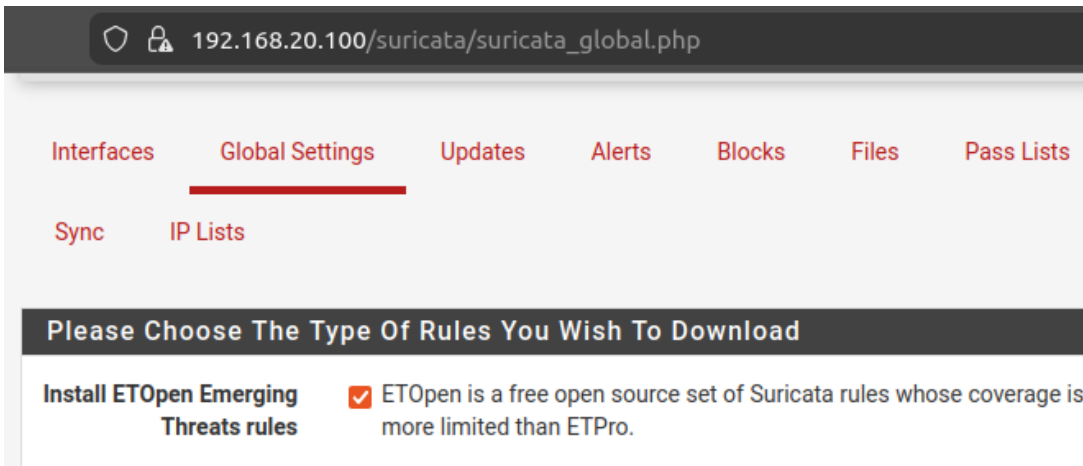
(foto)

## Definició de Polítiques de Seguretat

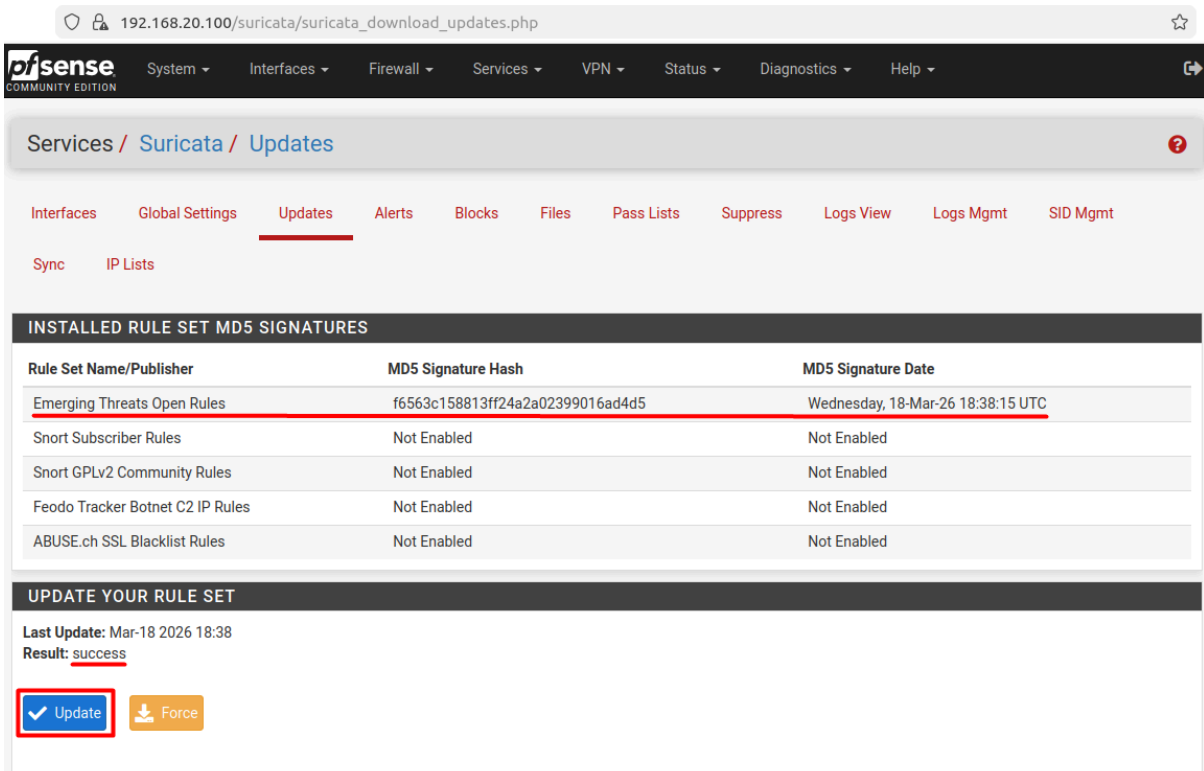
### 1. Regles i signatures per a la detecció i prevenció

- Paquet Estàndard i Gratuït

A les opcions generals, activem l'opció per instal·lar les Emerging Threats Rules.



Després hem d'anar a Updates i apretar Update per descarregar-les. Una vegada aparegui success, veurem que tenim un hash definit i la data d'instal·lació.



#### - Regles Personalitzades

Ja hem descarregat un set predefinit de regles i el tenim activat i preparat per funcionar, a part d'això, volem tenir les nostres pròpies regles personalitzades a Suricata. Hem estat debatint sobre els possibles atacs que podem rebre per part dels atacants.

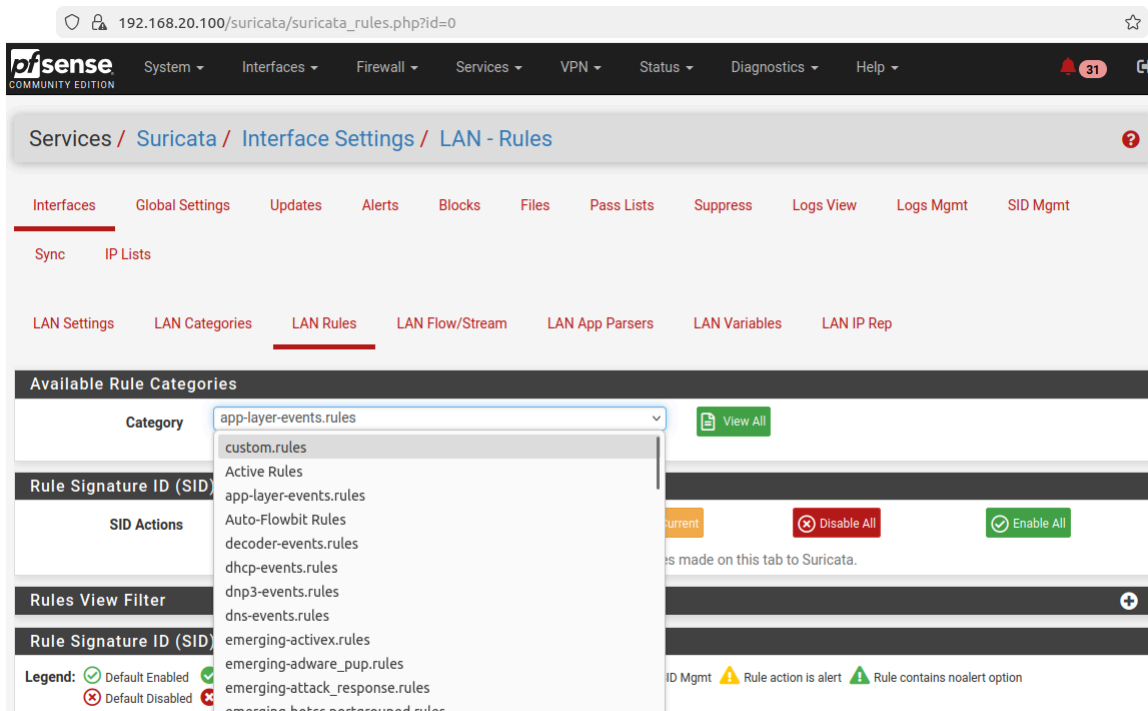
Amenaces a la xarxa WAN:

- Escaneig de la xarxa
- Intent d'accés a fitxers sensibles
- Atacs de força bruta
- SQL Injection
- Atacs DDOS

## Amenaces a la xarxa LAN:

- Escaneig de la xarxa
- Pujar o descarregar arxius .exe
- Utilitzar protocols no segurs

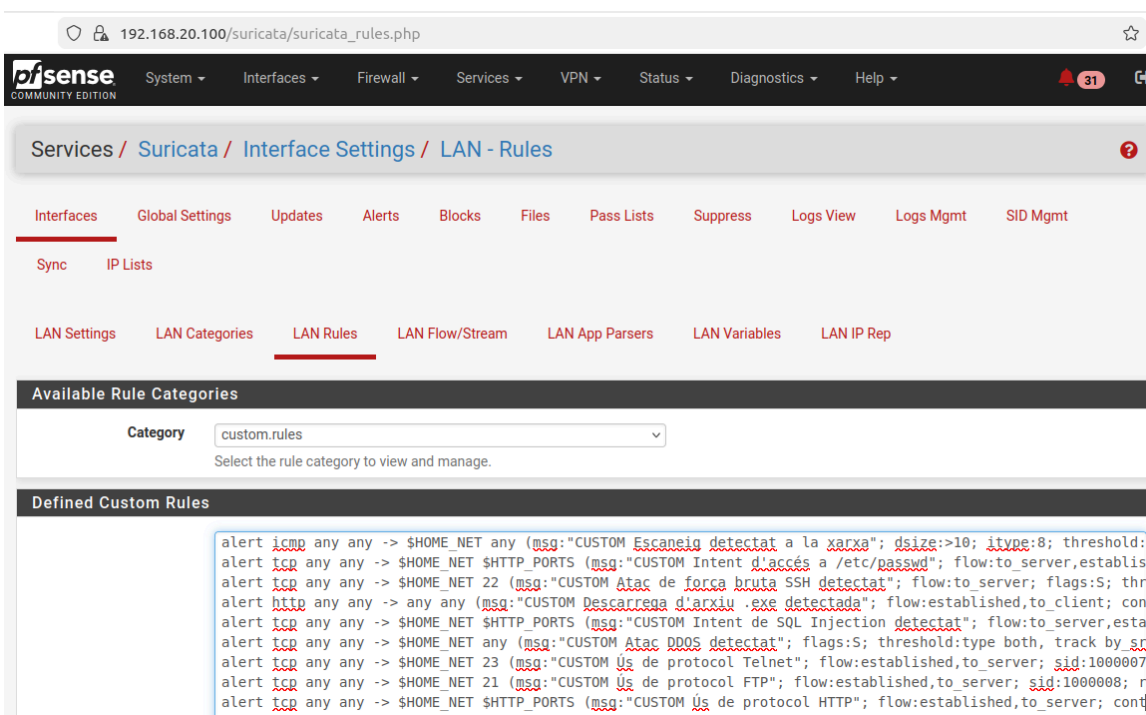
Per crear regles personalitzades, editem la interfície a Suricata de la xarxa LAN que tenim configurada i dintre de la pestanya Rules, tenim l'opció d'introduir regles personalitzades a custom.rules.



Introduim les regles que alerten de les amenaces de la llista pel mateix ordre.

|                                                                     |                                                                                                                                                                                                                      |
|---------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Detecta si hi ha molts pings seguits a diferents IP's de la xarxa.  | alert icmp any any -> \$HOME_NET any (msg:"CUSTOM Escaneig detectat a la xarxa"; dsize:>10; itype:8; threshold:type both, track by_src, count 10, seconds 10; sid:1000001; rev:1;)                                   |
| Detecta si algú intenta llegir el contingut de l'arxiu /etc/passwd. | alert tcp any any -> \$HOME_NET \$HTTP_PORTS (msg:"CUSTOM Intent d'accés a /etc/passwd"; flow:to_server,established; content:"/etc/passwd"; http_uri; sid:1000002; rev:1;)                                           |
| Alerta quan detecta 5 intents de connexió per SSH en menys de 60s.  | alert tcp any any -> \$HOME_NET 22 (msg:"CUSTOM Atac de força bruta SSH detectat"; flow:to_server; flags:S; threshold:type both, track by_src, count 5, seconds 60; sid:1000003; rev:1;)                             |
| Detecta si es puja o es descarrega un arxiu .exe a través d'http    | alert http any any -> any any (msg:"CUSTOM Descarrega d'arxiu .exe detectada"; flow:established,to_client; content:".exe"; http_uri; sid:1000004; rev:1;)                                                            |
| Alerta si es fan intents comuns d'injecció de codi SQL.             | alert tcp any any -> \$HOME_NET \$HTTP_PORTS (msg:"CUSTOM Intent de SQL Injection detectat"; flow:to_server,established; content:"select"; nocase; http_uri; content:"union"; nocase; http_uri; sid:1000005; rev:1;) |

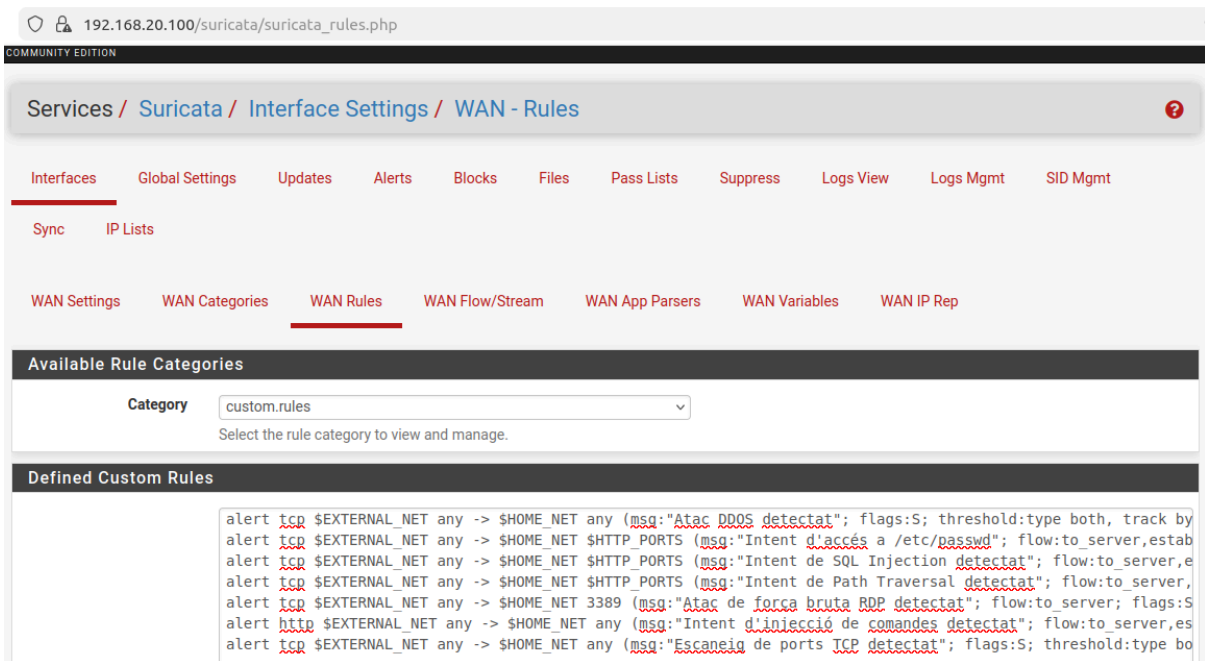
|                                                                          |                                                                                                                                                                                                                                                                                                                                                                                                     |
|--------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                          | flow:established,to_server; sid:1000007; rev:1;)                                                                                                                                                                                                                                                                                                                                                    |
| Detecta enviaments massius de paquets, atacs DDoS per fer caure serveis. | alert tcp any any -> \$HOME_NET any (msg:"CUSTOM Atac DDoS detectat"; flags:S; threshold:type both, track by_src, count 100, seconds 1; sid:1000006; rev:1;)                                                                                                                                                                                                                                        |
| Alerta quan s'utilitzen protocols no segurs com, telnet, ftp i http.     | alert tcp any any -> \$HOME_NET 23 (msg:"CUSTOM Ús de protocol Telnet";<br>alert tcp any any -> \$HOME_NET 21 (msg:"CUSTOM Ús de protocol FTP"; flow:established,to_server; sid:1000008; rev:1;)<br>alert tcp any any -> \$HOME_NET \$HTTP_PORTS (msg:"CUSTOM Ús de protocol HTTP";<br>flow:established,to_server; content:"POST"; http_method;<br>content:"password"; nocase; sid:1000009; rev:1;) |



Ara és el torn de les regles per la xarxa WAN.

|                                                                                                            |                                                                                                                                                                                |
|------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Detecta un atac de denegació de servei si es reben 10 paquets SYN en 1 segon des de la mateixa IP externa. | alert tcp \$EXTERNAL_NET any -> \$HOME_NET any (msg:"Atac DDoS detectat"; flags:S; threshold:type both, track by_src, count 100, seconds 1; sid:1000010; rev:1;)               |
| Detecta si un atacant extern intenta llegir l'arxiu crític /etc/passwd mitjançant el protocol HTTP.        | alert tcp \$EXTERNAL_NET any -> \$HOME_NET \$HTTP_PORTS (msg:"Intent d'accés a /etc/passwd"; flow:to_server,established; content:"/etc/passwd"; http_uri; sid:1000011; rev:1;) |
| Alerta quan es detecten paraules clau típiques d'una injecció SQL (select i union)                         | alert tcp \$EXTERNAL_NET any -> \$HOME_NET \$HTTP_PORTS (msg:"Intent de SQL Injection detectat"; flow:to_server,established; content:"select"; nocase; http_uri;               |

|                                                                                                            |                                                                                                                                                                                                |
|------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| en una petició web.                                                                                        | content:"union"; nocase; http_uri; sid:1000012; rev:1;)                                                                                                                                        |
| Detecta intents de navegació no autoritzada per directoris utilitzant "../" a la URL.                      | alert tcp \$EXTERNAL_NET any -> \$HOME_NET \$HTTP_PORTS (msg:"Intent de Path Traversal detectat"; flow:to_server,established; content:"../"; http_uri; sid:1000013; rev:1;)                    |
| Alerta quan detecta 5 intents de connexió per escriptori remot en menys de 60 segons des d'una IP externa. | alert tcp \$EXTERNAL_NET any -> \$HOME_NET 3389 (msg:"Atac de força bruta RDP detectat"; flow:to_server; flags:S; threshold:type both, track by_src, count 5, seconds 60; sid:1000014; rev:1;) |
| Detecta intents d'execució remota de comandes analitzant les capçaleres de les peticions HTTP.             | alert http \$EXTERNAL_NET any -> \$HOME_NET any (msg:"Intent d'injecció de comandes detectat"; flow:to_server,established; content:"()" {""; http_header; sid:1000015; rev:1;)                 |
| Detecta un escaneig de ports TCP si s'intenten obrir 20 connexions en 10 segons des d'una sola IP.         | alert tcp \$EXTERNAL_NET any -> \$HOME_NET any (msg:"Escaneig de ports TCP detectat"; flags:S; threshold:type both, track by_src, count 20, seconds 10; sid:1000016; rev:1;)                   |



## 2. Polítiques específiques per zones de la xarxa

### - WAN

Per aquesta interfície volem que actui com a defensa perimetral, impedit que entri qualsevol amenaça que pugui corrompre la seguretat de la nostra xarxa privada.

Del ruleset de ET Open Rules que hem instal·lat abans, hem decidit activar aquestes regles:

- botcc.rules: Llista de botnets coneguts.
- ciarmy.rules: IP's reportades que són atacants

- compromised.rules: Servidors compromesos per hackejos
- dos.rules: Atacs de denegació de servei.
- drop.rules: Malware i Spam registrat
- exploit.rules: Intents d'aprofitar-se de vulnerabilitats
- scan.rules: Escanejos de ports

| Ruleset:                            |                                                  |
|-------------------------------------|--------------------------------------------------|
| Enabled                             | Ruleset: ET Open Rules                           |
| <input type="checkbox"/>            | <a href="#">emerging-activex.rules</a>           |
| <input type="checkbox"/>            | <a href="#">emerging-adware_pup.rules</a>        |
| <input type="checkbox"/>            | <a href="#">emerging-attack_response.rules</a>   |
| <input type="checkbox"/>            | <a href="#">emerging-botcc.portgrouped.rules</a> |
| <input checked="" type="checkbox"/> | <a href="#">emerging-botcc.rules</a>             |
| <input type="checkbox"/>            | <a href="#">emerging-chat.rules</a>              |
| <input checked="" type="checkbox"/> | <a href="#">emerging-ciarmy.rules</a>            |
| <input type="checkbox"/>            | <a href="#">emerging-coinminer.rules</a>         |
| <input checked="" type="checkbox"/> | <a href="#">emerging-compromised.rules</a>       |
| <input type="checkbox"/>            | <a href="#">emerging-current_events.rules</a>    |
| <input type="checkbox"/>            | <a href="#">emerging-deleted.rules</a>           |
| <input type="checkbox"/>            | <a href="#">emerging-dns.rules</a>               |
| <input checked="" type="checkbox"/> | <a href="#">emerging-dos.rules</a>               |
| <input checked="" type="checkbox"/> | <a href="#">emerging-drop.rules</a>              |
| <input type="checkbox"/>            | <a href="#">emerging-dshield.rules</a>           |
| <input type="checkbox"/>            | <a href="#">emerging-dyn_dns.rules</a>           |
| <input checked="" type="checkbox"/> | <a href="#">emerging-exploit.rules</a>           |
| <input checked="" type="checkbox"/> | <a href="#">emerging-scan.rules</a>              |

## - LAN

A la LAN hem d'intentar buscar amenaces que ja estiguin dintre de la xarxa, no bloquejar l'entrada com a la WAN, per això activem les següents regles per protegir-nos contra les infeccions, prevenir fugues i que com:

- attack\_response.rules: Detecta si un atac realitzat al servidor ha tingut èxit.
- current\_events.rules: Conté firmes de les amenaces noves que han sortit.
- inappropriate.rules: Consulta que el tràfic no hi hagi continguts no aptes per entorns laborals.
- info.rules: S'encarrega de vigilar que els sistemes no deixi informació sensible a la xarxa.
- malware.rules: Té una base de dades amb virus famosos, detecta si un ordinador està infectat.
- misc.rules: Inclou comportaments estranys i sospitosos.
- p2p.rules: Protegeix que el rendiment de la xarxa no sigui alterat per tràfic p2p.

| Ruleset:                            |                                  |
|-------------------------------------|----------------------------------|
| Enabled                             | Ruleset: ET Open Rules           |
| <input type="checkbox"/>            | emerging-activex.rules           |
| <input type="checkbox"/>            | emerging-adware_pup.rules        |
| <input checked="" type="checkbox"/> | emerging-attack_response.rules   |
| <input type="checkbox"/>            | emerging-botcc.portgrouped.rules |
| <input type="checkbox"/>            | emerging-botcc.rules             |
| <input type="checkbox"/>            | emerging-chat.rules              |
| <input type="checkbox"/>            | emerging-ciarmy.rules            |
| <input type="checkbox"/>            | emerging-coinminer.rules         |
| <input type="checkbox"/>            | emerging-compromised.rules       |
| <input checked="" type="checkbox"/> | emerging-current_events.rules    |
| <input checked="" type="checkbox"/> | emerging-inappropriate.rules     |
| <input checked="" type="checkbox"/> | emerging-info.rules              |
| <input type="checkbox"/>            | emerging-ja3.rules               |
| <input checked="" type="checkbox"/> | emerging-malware.rules           |
| <input checked="" type="checkbox"/> | emerging-misc.rules              |
| <input type="checkbox"/>            | emerging-mobile_malware.rules    |
| <input type="checkbox"/>            | emerging-netbios.rules           |
| <input checked="" type="checkbox"/> | emerging-p2p.rules               |

### 3. Establiment del mecanisme de respostes contra incidents

A les dues interfícies, volem que Suricata actuï com a IPS. Per fer això, a la configuració de les interfícies, hem d'activar Block Offenders, seleccionar el mode, en el nostre cas com treballem amb màquines virtuals el Legacy i activem Kill States per tallar la connexió immediatament.

Primer configurarem la interfície WAN.

Alert and Block Settings

Block Offenders
☒
Checking this option will automatically block hosts that generate a Suricata alert.

IPS Mode
Legacy Mode

Select blocking mode operation. Legacy Mode inspects copies of packets while Inline Mode inserts the Suricata inspection engine into the network stack between the NIC and the OS. Default is Legacy Mode.

Legacy Mode uses the PCAP engine to generate copies of packets for inspection as they traverse the interface. Some "leakage" of packets will occur before Suricata can determine if the traffic matches a rule and should be blocked. Inline mode instead intercepts and inspects packets before they are handed off to the host network stack for further processing. Packets matching DROP rules are simply discarded (dropped) and not passed to the host network stack. No leakage of packets occurs with Inline Mode. WARNING: Inline Mode only works with NIC drivers which properly support Netmap! Supported drivers include: bnxt, cc, cxgbe, cxl, em, ena, ice, igb, igc, ix, ixgbe, ixl, lem, re, vmx, vtnet. If problems are experienced with Inline Mode, switch to Legacy Mode instead.

Kill States
☒
Checking this option will kill firewall states for the blocked IP. Default is Checked.

Ara des de la meua màquina real, llançarem un nmap contra la IP de la interfície WAN del pfSense.



- e eth6 per forçar que nmap envii per la interfície eth6, que correspon a la xarxa 10.93.0.0/16 (WAN).
- Pn per no fer la detecció del host, no busca que estigui actiu.
- sT per fer un escaneig de connexió TCP.
- p- perquè envii per tots els ports.

```
C:\Windows\System32>nmap -e eth6 -Pn -sT -p- -T4 10.93.255.94
Starting Nmap 7.99 ( https://nmap.org ) at 2026-03-27 16:37 +0100
```

Suricata ens ha enviat alertes avisant que estan escanejant el port 3306

Services / Suricata / Alerts

Alert Log View Settings

Instance to View: (WAN) WAN  
Choose which instance alerts you want to inspect.

Save or Remove Logs: [Download](#) [Clear](#)  
All alert log files for selected interface will be downloaded. Clear the currently active Alerts log file.

Save Settings: [Save](#) ☒ Refresh  
Save auto-refresh and view settings. Default is ON.

Number of alerts to display. Default is 250.

Alert Log View Filter

Last 250 Alert Entries. (Most recent entries are listed first)

| Date                | Action | Pri | Proto | Class                   | Src           | SPort | Dst          | DPort | GID:SID   | Description                                   |
|---------------------|--------|-----|-------|-------------------------|---------------|-------|--------------|-------|-----------|-----------------------------------------------|
| 03/28/2026 04:39:38 | ⚠      | 2   | TCP   | Potentially Bad Traffic | 10.93.255.185 | 39383 | 10.93.255.94 | 3306  | 1:2010937 | ET SCAN Suspicious inbound to MySQL port 3306 |
| 03/28/2026 04:39:36 | ⚠      | 2   | TCP   | Potentially Bad Traffic | 10.93.255.185 | 10855 | 10.93.255.94 | 3306  | 1:2010937 | ET SCAN Suspicious inbound to MySQL port 3306 |

Mirem a la pestanya Blocks i ens trobem que ens ha bloquejat la IP 10.93.255.185 (màquina real) per l'escaneig realitzat al MySQL.

192.168.20.100/suricata/suricata\_blocked.php

Services / Suricata / Blocked Hosts

Interfaces Global Settings Updates Alerts **Blocks** Files Pass Lists Suppress Logs View Logs Mgmt SID Mgmt

Sync IP Lists

**Blocked Hosts Log View Settings**

Save or Remove Hosts [Download](#) [Clear](#)

All blocked hosts will be saved All blocked hosts will be cleared

Save Settings [Save](#) ☒ Refresh

Save auto-refresh and view settings Default is ON Number of blocked entries to view. Default is 500

**Last 500 Hosts Blocked by Suricata**

**Note:** Only blocked IP addresses from Legacy Mode interfaces are shown! For inline IPS mode interfaces, dropped IP addresses are highlighted on the ALERTS tab.

| Blocked IP    | Block Date/Time     | Block Alert Description                       | Block Rule GID:SID | Remove Block      |
|---------------|---------------------|-----------------------------------------------|--------------------|-------------------|
| 10.93.255.185 | 03/28/2026 04:39:36 | ET SCAN Suspicious inbound to MySQL port 3306 | 1:2010937          | <a href="#">X</a> |
|               | 03/28/2026 02:35:29 | ET SCAN Suspicious inbound to MySQL port 3306 | 1:2010937          |                   |

1 host IP address is currently being blocked.

## Anàlisi de Logs i Alertes

### 1. Configuració del sistema de logs detallats

#### - EVE JSON

He trobat una opció a Suricata que permet generar logs amb molta més informació en format JSON, es diu EVE.

**EVE Output Settings**

**EVE JSON Log** ☐ Suricata will output selected info in JSON format to a single file or to syslog. Default is Not Checked.

Una vegada activada, se'ns despleguen un munt de configuracions per aquesta funció. Per exemple, hem activat EVE Log Anomalies, d'aquesta manera detectarà els paquets mal formats a la xarxa, que són estranys.

**EVE Log Anomalies** ☒ Suricata will log packet anomalies such as truncated packets, packets with invalid IP/UDP/TCP length values and other events that render the packet invalid for further processing. Networks with high rates of anomalies may experience packet processing degradation.

**EVE Log Anomaly Details** ☐ Log packet decode anomaly events. ☐ Log packet stream anomaly events. ☒ Log packet applayer anomaly events. ☐ Log packet header for anomaly events.

Select which details Suricata will use to enrich anomaly logging.

A l'apartat d'EVE Logged Traffic, hem modificat la configuració per defecte desactivant el protocol IKE i SIP i activant PostgreSQL i RDP.

IKE és un protocol per establir túnels VPN, com no tenim cap VPN, llavors no ens serveix per a res i només ens ocuparia ús de CPU i espai al disc.

Nosaltres no tenim cap servei veu, llavors no necessitem monitoritzar el protocol SIP

Activant PostgreSQL estem protegint les consultes que es fan contra la base de dades, en el cas que l'atacant ja hagi accedit a la xarxa i també impeding atacs de força bruta contra usuaris i intents d'injecció de codi SQL.

Volem tenir control sobre RDP perquè és un dels més utilitzats per realitzar atacs de Ransomware. També ens serveix per generar logs on podrem revisar qui i quan ha intentat accedir a qualsevol màquina remotament.

**EVE Logged Traffic**

☐ BitTorrent
 ☒ DNS
 ☒ FTP
 ☒ HTTP
 ☒ HTTP2
 ☐ IKE
 ☒ Kerberos
 ☒ NFS
 ☒ PostgreSQL

☒ QUICv1
 ☒ RDP
 ☒ RFB
 ☐ SIP
 ☒ SMB
 ☒ SMTP
 ☒ TFTP

Choose the traffic types to log via EVE JSON output.

Amb l'opció de Flows activada, podem monitoritzar els fluxos que hi ha a la xarxa, quines màquines s'han comunicat, el temps que ha durat la connexió, a quina hora s'ha fet, la mida dels paquets intercanviats...

**EVE Logged Info**

☒ DHCP Messages
 ☒ Flows
 ☒ MQTT
 ☐ Net Flows
 ☐ Perf Stats
 ☒ SNMP

☒ SSH Handshakes
 ☒ TLS Handshakes
 ☒ Tracked Files

Choose the information to log via EVE JSON output.

## - Logs Mgmt

Amb EVE Log configurat, ens hem d'assegurar que no tindrem problemes amb l'espai que ocupen els logs generats, per això ara configurarem Log mgmt.

Hem implementat un sistema que gestiona els logs amb un límit estricte de 2GB al directori sencer, als logs d'alertes i bloquejos els hi hem augmentat el límit de cada arxiu a 5MB, que els eliminarà automàticament quan passin 14 dies.

Interfaces Global Settings Updates Alerts Blocks Files Pass Lists Suppress Logs View **Logs Mgmt** SID Mgmt

Sync IP Lists

**General Settings**

**Auto Log Management** ☒ Enable automatic unattended management of Suricata logs using parameters specified below. Default is checked.

**Remove Suricata Logs On Package Uninstall** ☐ Suricata log files will be removed when the Suricata package is uninstalled. Default is not checked.

**Log Directory Size Limit**

**Log Directory Size Limit** ☒ Enable Directory Size Limit

**Log Limit Size in MB**

This setting imposes a hard-limit on the combined log directory size of all Suricata interfaces. When the size limit set is reached, rotated logs for all interfaces will be removed, and any active logs pruned to zero-length. (default is 20% of available free disk space)

**Log Size and Retention Limits**

| Log Type | Size Limit                                                                     | Retention                                 |
|----------|--------------------------------------------------------------------------------|-------------------------------------------|
| alert    | 5 MB<br>Max Size. Default is 500 KB.<br>Suricata alerts and event details      | 14 DAYS<br>Retention. Default is 14 DAYS. |
| block    | 5 MB<br>Max Size. Default is 500 KB.<br>Suricata blocked IPs and event details | 14 DAYS<br>Retention. Default is 14 DAYS. |

Als arxius d'eve-json li hem assignat el màxim d'espai possible, 10MB, com monitoritza molts protocols, els arxius d'aquest tipus s'ompliran molt ràpid, llavors volem mantenir-los més temps que els altres, 30 dies.

**eve-json**

Max Size. Default is 5 MB. Retention. Default is 7 DAYS.

Eve-JSON (JavaScript Object Notation) data

Copiem la configuració d'EVE que acabem de fer a la WAN.

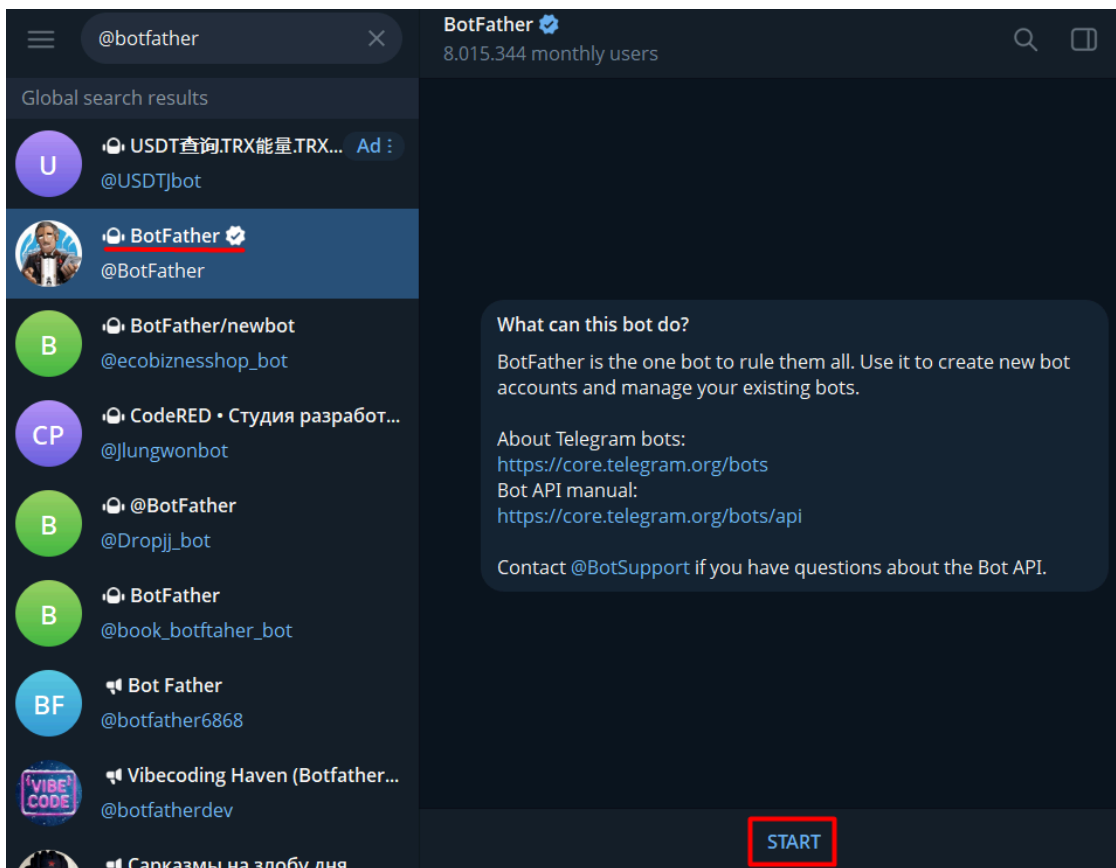
## 2. Implementació d'un sistema d'alerta temprana contra amenaces

Necessitem configurar un sistema que ens comuniqui quan aparegui una alerta a Suricata, per no haver d'estar pendent de les alertes ni els logs buscant si hi ha aparegut alguna amenaça que el nostre IDS/IPS hagi detectat o bloquejat.

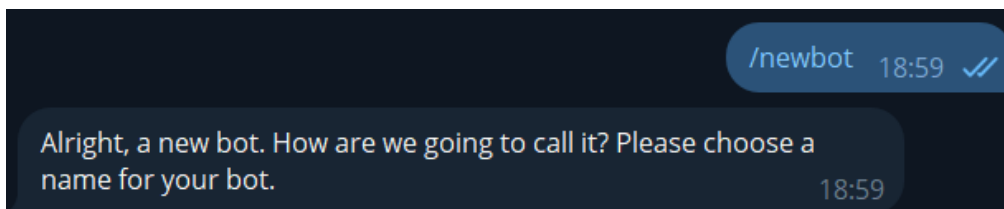
### - Telegram

Utilitzarem Telegram.

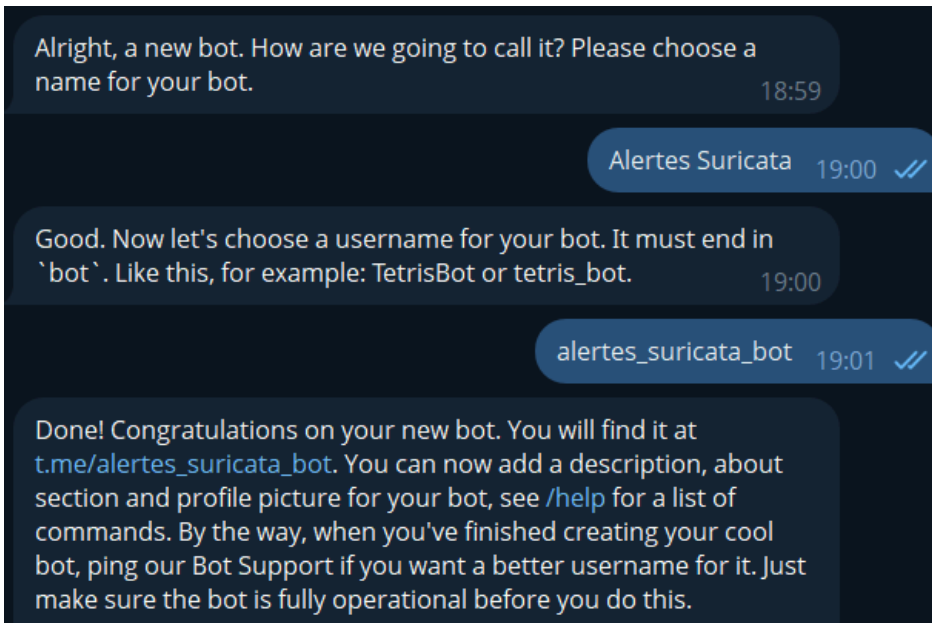
Des de l'aplicació de Telegram, busquem @BotFather, cliquem Start al que tingui el tic blau verificat.



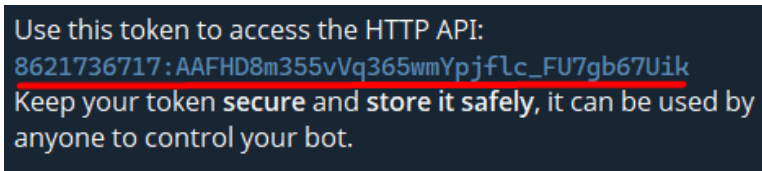
Dintre del chat del bot, introduïm /newbot.



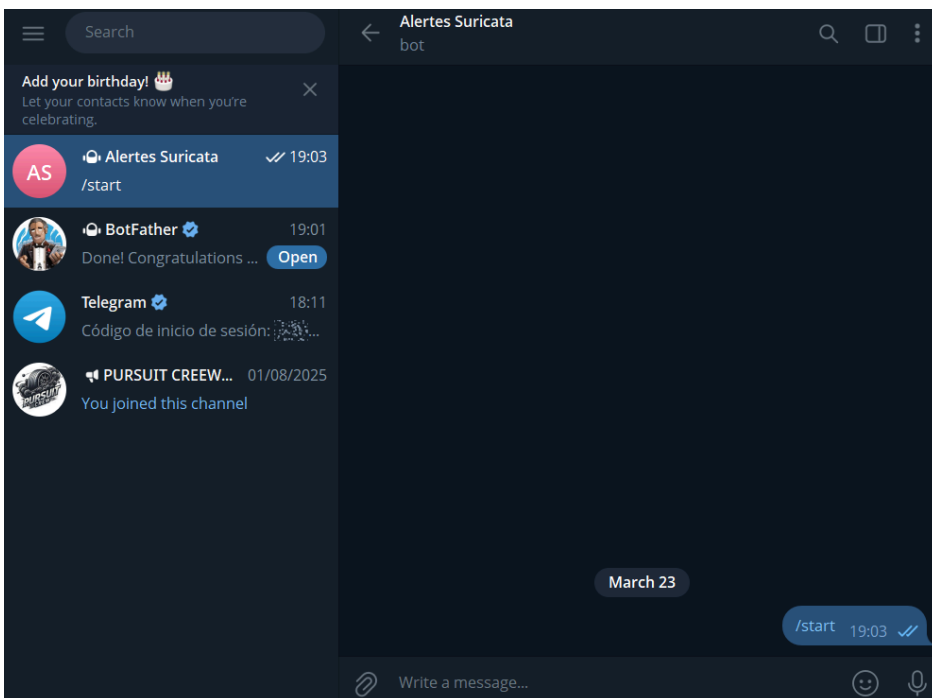
Inserim el nom que tindrà i el seu usuari.



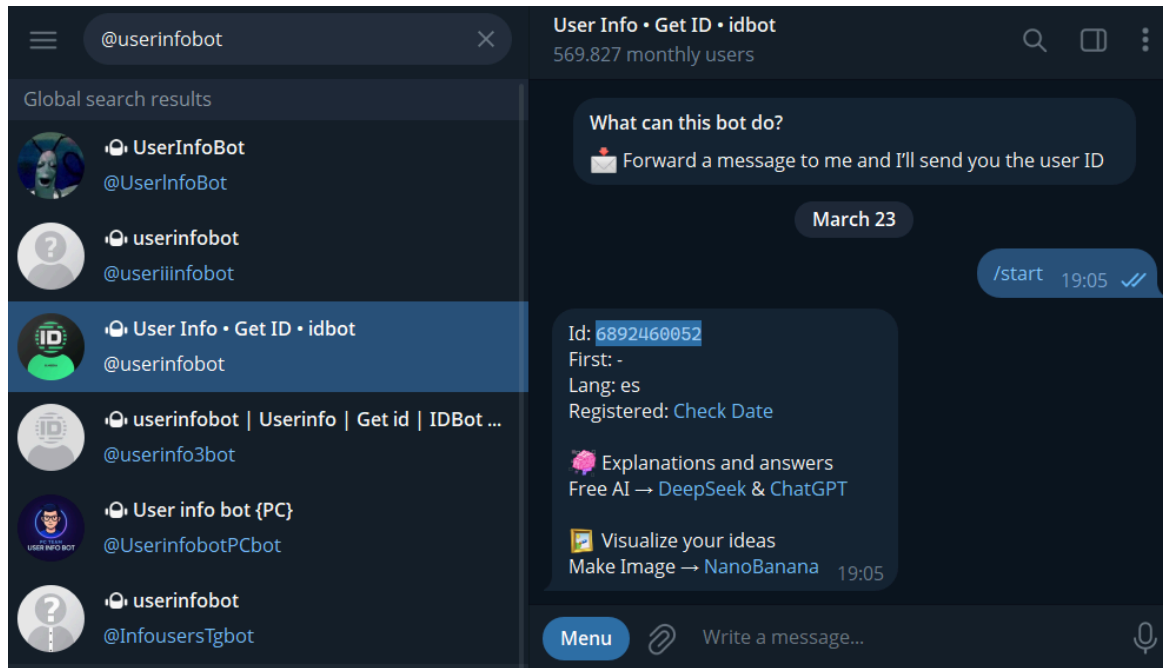
Ens guardem el token que ens dona per configurar el bot al pfSense.



Seguidament, sortim de la conversa i entrem a la del bot que acabem de crear, dintre pitgem iniciar.



Finalment, obtenim el nostre id d'usuari buscant el bot anomenat @userinfobot i iniciant-lo.



#### - pfSense

Tornem al pfSense, hem d'anar a la pestanya Sistema → Advanced → Notifications. Busquem la secció telegram, l'activem i omplim els camps.

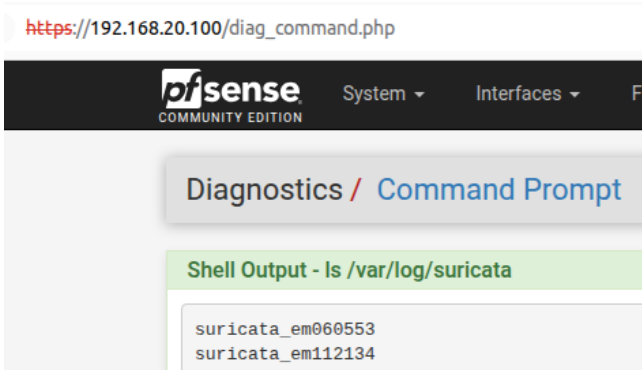
| Telegram                      |                                                                                                                                                                                                                         |
|-------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Enable Telegram</b>        | <input checked="" type="checkbox"/> Enable Telegram Notifications<br>Check this option to enable Telegram notifications.<br>You will need a Telegram Bot and its associated API key. <a href="#">Instructions here.</a> |
| <b>API Key</b>                | <input type="text" value="8621736717:AAFHD8m355vVq365wmYpjfic_FU7gb67Uik"/><br>Enter the Bot API key required to authenticate with the Telegram API server.                                                             |
| <b>Chat ID</b>                | <input type="text" value="6892460052"/><br>Enter the chat ID number (private) or channel @username (public) that will be used to send the notifications to.                                                             |
| <b>Test Telegram Settings</b> | <input type="button" value="Test Telegram Settings"/><br>A test notification will be sent even if the service is not enabled. The last SAVED values will be used, not necessarily the values displayed here.            |

Instal·lem el paquet Cron.

| Packages |         |                                                            |
|----------|---------|------------------------------------------------------------|
| Name     | Version | Description                                                |
| Cron     | 0.3.8_3 | The cron utility is used to manage commands on a schedule. |



Executo ls per veure el nom de la interfície



Creem un nou fitxer .php al pfSense que contingui el token del bot, el id de l'usuari i la ruta al fitxer de logs, seguidament que agafi l'últim fitxer i la última línia d'aquest. Comprova que no estigui buida i després crea el missatge amb el contingut de l'alerta que sigui per enviar-ho al nostre telegram.

```
<?php
$token = '8621736717:AAFHD8m355vVq365wmYpjflc_FU7gb67Uik';
$chatid = '6892460052';
$log = '/var/log/suricata/suricata_em060553/alerts.log';
$ultim_fitxer = '/tmp/suricata_last_event.txt';

$ultima_linia = shell_exec("/usr/bin/tail -n 1 " . escapeshellarg($log));
$ultima_linia = trim($ultima_linia);

if (empty($ultima_linia)) {
    die("Log no trobat.");
}

$ultim_enviat = file_exists($ultim_fitxer) ? trim(file_get_contents($ultim_fitxer)) : '';

if ($ultima_linia !== $ultim_enviat) {
    file_put_contents($ultim_fitxer, $ultima_linia);

    $missatge_net = mb_convert_encoding($ultima_linia, 'UTF-8', 'UTF-8');
    $missatge_final = "ALERTA A SURICATA" . $missatge_net;

    $url = "https://api.telegram.org/bot{$token}/sendMessage";
    $postData = [
        'chat_id' => $chatid,
        'text' => $missatge_final
    ];

    $ch = curl_init($url);
    curl_setopt($ch, CURLOPT_RETURNTRANSFER, true);
    curl_setopt($ch, CURLOPT_POSTFIELDS, http_build_query($postData));
    curl_setopt($ch, CURLOPT_SSL_VERIFYPEER, false);

    $resultat = curl_exec($ch);
    curl_close($ch);

    echo "Resposta API: " . $resultat;
} else {
    echo "No hi ha noves alertes.";
}
?>
```

Amb el cron, afegim una tasca que executi cada segon el fitxer de telegram.php per verificar si ha aparegut una nova alerta.

[https://192.168.20.100/packages/cron/cron\\_edit.php](https://192.168.20.100/packages/cron/cron_edit.php)

Services / Cron / **Add**

**Settings** **Add**

### Add A Cron Schedule

|                   |                                                                                                                      |                                                                                                                                                                                                                          |
|-------------------|----------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Minute            | <input type="text" value="*"/>                                                                                       | The minute(s) at which the command will be executed or a special @ event string. (0-59, ranges, divided, @ event or delay, *=all)<br>When using a special @ event, such as @reboot, the other time fields must be empty. |
| Hour              | <input type="text" value="*"/>                                                                                       | The hour(s) at which the command will be executed. (0-23, ranges, or divided, *=all)                                                                                                                                     |
| Day of the Month  | <input type="text" value="*"/>                                                                                       | The day(s) of the month on which the command will be executed. (1-31, ranges, or divided, *=all)                                                                                                                         |
| Month of the Year | <input type="text" value="*"/>                                                                                       | The month(s) of the year during which the command will be executed. (1-12, ranges, or divided, *=all)                                                                                                                    |
| Day of the Week   | <input type="text" value="*"/>                                                                                       | The day(s) of the week on which the command will be executed. (0-7, 7=Sun or use names, ranges, or divided, *=all)                                                                                                       |
| User              | <input type="text" value="root"/>                                                                                    | The user executing the command (typically "root")                                                                                                                                                                        |
| Command           | <input type="text" value="/usr/local/bin/php /root/telegram.php"/><br>The full path to the command, plus parameters. |                                                                                                                                                                                                                          |

I fem unes quantes proves per veure si salten les alertes i ens les envia al telegram.

```
C:\Users\drui>ssh alume@10.93.255.94
ssh: connect to host 10.93.255.94 port 22: Connection timed out

C:\Users\drui>curl --interface 10.93.255.185 -H "User-Agent: () { : }; echo vulnerable" http://10.93.255.94/
<html>
<head><title>301 Moved Permanently</title></head>
<body>
<center><h1>301 Moved Permanently</h1></center>
<hr><center>nginx</center>
</body>
</html>

C:\Users\drui>curl --interface 10.93.255.185 "http://10.93.255.94/?file=/etc/passwd"
^C
C:\Users\drui>curl --interface 10.93.255.185 "http://10.93.255.94/?file=/etc/passwd"
<html>
<head><title>301 Moved Permanently</title></head>
<body>
<center><h1>301 Moved Permanently</h1></center>
<hr><center>nginx</center>
</body>
</html>

C:\Users\drui>
```

**Alertes Suricata**  
bot

[\*\*] [1:2001219:20] ET SCAN Potential SSH Scan  
[\*\*] [Classification: Attempted Information Leak] [Priority: 2] (TCP) 10.93.255.185:42714 -> 10.93.255.94:22 18:31

ALERTA A SURICATA05/04/2026-18:16:28.461670  
[\*\*] [1:2001219:20] ET SCAN Potential SSH Scan  
[\*\*] [Classification: Attempted Information Leak] [Priority: 2] (TCP) 10.93.255.185:43123 -> 10.93.255.94:22 18:35

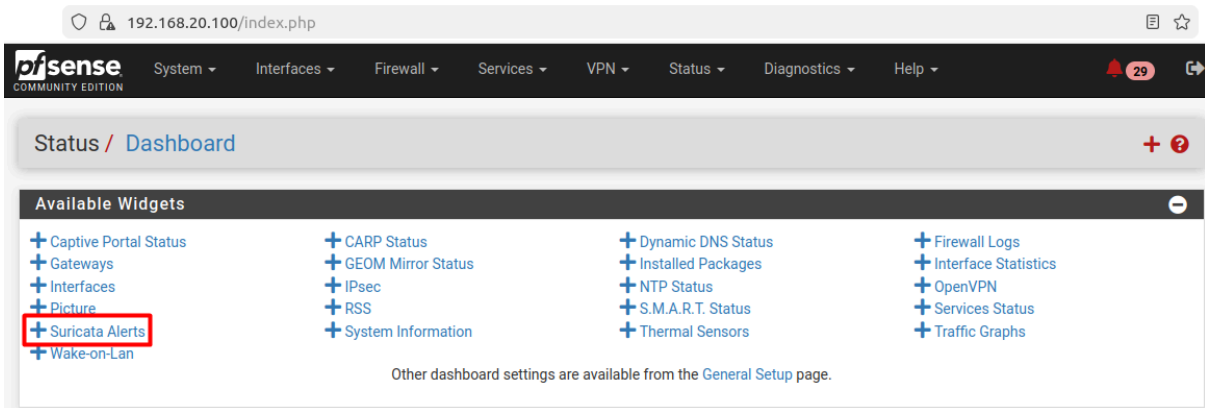
ALERTA A SURICATA05/04/2026-18:19:38.474353  
[\*\*] [1:1000015:1] Intent d'injecció de comandes detectat [\*\*] [Classification: (null)] [Priority: 3] (TCP) 10.93.255.185:25687 -> 10.93.255.94:80 18:35

ALERTA A SURICATA05/04/2026-18:25:44.103893  
[\*\*] [1:1000011:1] Intent d'accés a /etc/passwd [\*\*] [Classification: (null)] [Priority: 3] (TCP) 10.93.255.185:4484 -> 10.93.255.94:80 18:36

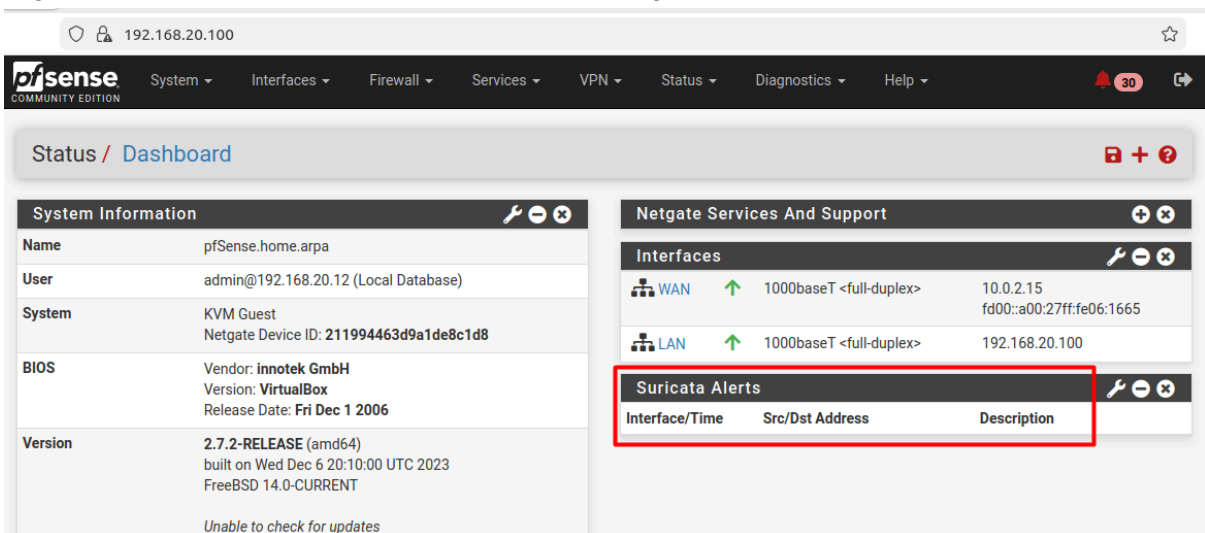
## - Dashboard

Perquè sigui molt més visual, afegirem un widget al panell de control de pfSense on apareixeran les alertes de Suricata.





D'aquesta manera les tenim a la vista a la finestra principal, podem revisar fàcilment cada vegada que entrem al servidor si hi ha cap amenaça.



### 3. Estudi de casos pràctics basats en activitat real

Per aquesta part, anem a analitzar el contingut dels diferents logs sobre els incidents reals detectats durant les proves.

#### - Log d'Atac DDoS (LAN)

04/09/2026-19:30:09.323536 [1:1000006:1] Atac DDOS detectat [Classification: (null)] [Priority: 3] {TCP} 192.168.20.10:64350 -> 192.168.20.100:85

El sistema dona l'alerta quan detecta una ráfaga de paquets TCP cap al port 85 des d'un equip de la xarxa LAN.

Si analitzem el log, trobem que l'atac s'ha produït el dia 9 d'Abril a les 7:30 de la tarda, amb un nivell de prioritat de 3 i el protocol del missatge ha sigut TCP. Per últim, indica la IP i port d'origen (192.168.20.10:64350) i el destí (192.168.20.100:85).

#### - Log d'Intent de Descàrrega d'Arxiu .exe (LAN)

04/13/2026-06:58:55.572197 [1:1000004:2] Intent de descàrrega .exe detectat [Classification: (null)] [Priority: 3] {TCP} 192.168.20.10:48446 -> 192.168.20.100:80

Aquest log s'ha registrat per un intent de descàrrega d'un arxiu .exe a través d'una URL al navegador.

Veiem que la data és el 13 d'Abril, també té 3 de prioritat i el protocol torna a ser TCP.

L'equip de la xarxa LAN amb la IP 192.168.20.10 ha intentat descarregar per http un arxiu .exe situat al dispositiu amb la IP 192.168.20.100.

- Log Escaneig al port 3306 (WAN)

```
03/28/2026-02:35:31.899044 [**] [1:2010937:3] ET SCAN Suspicious inbound to mySQL
port 3306 [**] [Classification: Potentially Bad Traffic] [Priority: 2] {TCP} 10.93.255.185:35782
-> 10.93.255.94:3306
```

Les firmes d'ET han detectat un escaneig cap al port 3306, que és el port predeterminat per les bases de dades MySQL.

Suricata l'ha detectat el 28 de Març, l'alerta es classifica com a probabilitat alta de tràfic dolent i un 2 de prioritat. També pel protocol TCP i atacant al port 3306, mostra que la IP origen és la 10.93.255.185 i la destí 10.93.255.94.

## Simulació d'Atacs i Resposta

### 1. Simulació d'atacs específics per a comprovar l'eficàcia del sistema.

- WAN

Fem la prova amb les regles personalitzades que hem creat.

Des de la meua màquina real, fem un curl des de la interfície amb la IP 10.93.255.185 cap a 10.93.255.94, que és la interfície de la xarxa WAN de pfSense i apuntem al fitxer etc/passwd.

```
C:\Users\druiz>curl --interface 10.93.255.185 "http://10.93.255.94/?file=/etc/passwd"
curl: (28) Failed to connect to 10.93.255.94 port 80 after 21006 ms: Could not connect to server
```

| Suricata Alerts |                     |                              |
|-----------------|---------------------|------------------------------|
| Interface/Time  | Src/Dst Address     | Description                  |
| WAN             | 10.93.255.185:11235 | Intent d'accés a /etc/passwd |
| Apr 09 17:16:30 | 10.93.255.94:80     |                              |

192.168.20.100/suricata/suricata\_blocked.php

Suricata

System ▾ Interfaces ▾ Firewall ▾ Services ▾ VPN ▾ Status ▾ Diagnostics ▾ Help ▾

Services / Suricata / Blocked Hosts

Interfaces

Global Settings

Updates

Alerts

Blocks

Files

Pass Lists

Suppress

Logs View

Logs Mgmt

SID Mgmt

Sync

IP Lists

Blocked Hosts Log View Settings

Save or Remove Hosts

Download

All blocked hosts will be saved

Clear

All blocked hosts will be cleared

Save Settings

Save

Save auto-refresh and view settings

☒ Refresh

Default is ON

500

Number of blocked entries to view.  
Default is 500

Last 500 Hosts Blocked by Suricata

Note: Only blocked IP addresses from Legacy Mode interfaces are shown! For inline IPS mode interfaces, dropped IP addresses are highlighted on the ALERTS tab.

| Blocked IP    | Block Date/Time     | Block Alert Description      | Block Rule GID:SID | Remove Block |
|---------------|---------------------|------------------------------|--------------------|--------------|
| 10.93.255.185 | 04/09/2026 17:16:30 | Intent d'accès a /etc/passwd | 1:1000011          | ✖            |

Netegem la llista de hosts bloquejats i continuem amb la injecció de codi SQL a la base de dades.

```
C:\Users\druiz>curl --interface 10.93.255.185 "http://10.93.255.94/?id=1+select+union+all+select"
<html>
<head><title>301 Moved Permanently</title></head>
<body>
<center><h1>301 Moved Permanently</h1></center>
<hr><center>nginx</center>
</body>
</html>

C:\Users\druiz>
```

| Suricata Alerts |                     |                                  |
|-----------------|---------------------|----------------------------------|
| Interface/Time  | Src/Dst Address     | Description                      |
| WAN             | 10.93.255.185:35093 | Intent de SQL Injection detectat |
| Apr 09 19:00:13 | 10.93.255.94:80     |                                  |

192.168.20.100/suricata/suricata\_blocked.php

Suricata

System ▾ Interfaces ▾ Firewall ▾ Services ▾ VPN ▾ Status ▾ Diagnostics ▾ Help ▾

Services / Suricata / Blocked Hosts

Interfaces

Global Settings

Updates

Alerts

Blocks

Files

Pass Lists

Suppress

Logs View

Logs Mgmt

SID Mgmt

Sync

IP Lists

Blocked Hosts Log View Settings

Save or Remove Hosts

Download

All blocked hosts will be saved

Clear

All blocked hosts will be cleared

Save Settings

Save

Save auto-refresh and view settings

☒ Refresh

Default is ON

500

Number of blocked entries to view.  
Default is 500

Last 500 Hosts Blocked by Suricata

Note: Only blocked IP addresses from Legacy Mode interfaces are shown! For inline IPS mode interfaces, dropped IP addresses are highlighted on the ALERTS tab.

| Blocked IP    | Block Date/Time     | Block Alert Description          | Block Rule GID:SID | Remove Block |
|---------------|---------------------|----------------------------------|--------------------|--------------|
| 10.93.255.185 | 04/09/2026 19:00:13 | Intent de SQL Injection detectat | 1:1000012          | ✖            |
|               | 04/09/2026 17:16:30 | Intent d'accès a /etc/passwd     | 1:1000011          |              |

Simulem un atac anomenat Shellshock que engaña a Apache per executar el contingut de User-Agent.

```
C:\Users\druiz>curl --interface 10.93.255.185 -H "User-Agent: () { :; }; echo vulnerable" http://10.93.255.94/
<html>
<head><title>301 Moved Permanently</title></head>
<body>
<center><h1>301 Moved Permanently</h1></center>
<hr><center>nginx</center>
</body>
</html>

C:\Users\druiz>
```

| Interface/Time         | Src/Dst Address                        | Description                            |
|------------------------|----------------------------------------|----------------------------------------|
| WAN<br>Apr 09 21:40:24 | 10.93.255.185:64503<br>10.93.255.94:80 | Intent d'injecció de comandes detectat |

192.168.20.100/suricata/suricata\_blocked.php

Services / Suricata / Blocked Hosts

Interfaces Global Settings Updates Alerts **Blocks** Files Pass Lists Suppress Logs View Logs Mgmt SID Mgmt

Sync IP Lists

**Blocked Hosts Log View Settings**

Save or Remove Hosts [Download](#) [Clear](#)

All blocked hosts will be saved All blocked hosts will be cleared

Save Settings [Save](#) ☒ Refresh

Save auto-refresh and view settings Default is ON Number of blocked entries to view. Default is 500

**Last 500 Hosts Blocked by Suricata**

**Note:** Only blocked IP addresses from Legacy Mode interfaces are shown! For inline IPS mode interfaces, dropped IP addresses are highlighted on the ALERTS tab.

| Blocked IP    | Block Date/Time     | Block Alert Description                | Block Rule GID:SID | Remove Block      |
|---------------|---------------------|----------------------------------------|--------------------|-------------------|
| 10.93.255.185 | 04/09/2026 21:40:24 | Intent d'injecció de comandes detectat | 1:1000015          | <a href="#">×</a> |
|               | 04/09/2026 19:00:13 | Intent de SQL Injection detectat       | 1:1000012          |                   |
|               | 04/09/2026 17:16:30 | Intent d'accés a /etc/passwd           | 1:1000011          |                   |

El paquet gratuït de ET, m'ha detectat un escaneig del port del SSH quan m'he intentat connectar al pfSense per SSH múltiples vegades.

Símbolo del sistema

```

C:\Users\druiz>ssh alumne@10.93.255.94

C:\Users\druiz>ssh alumne@10.93.255.94

C:\Users\druiz>ssh alumne@10.93.255.94

C:\Users\druiz>ssh alumne@10.93.255.94

C:\Users\druiz>ssh alumne@10.93.255.94

C:\Users\druiz>ssh alumne@10.93.255.94

C:\Users\druiz>

```

|                 |                     |                            |
|-----------------|---------------------|----------------------------|
| WAN             | 10.93.255.185:44777 | ET SCAN Potential SSH Scan |
| Apr 10 05:49:12 | 10.93.255.94:22     |                            |
| WAN             | 10.93.255.185:44771 | ET SCAN Potential SSH Scan |
| Apr 10 05:47:14 | 10.93.255.94:22     |                            |

També m'ha bloquejat.

192.168.20.100/suricata/suricata\_blocked.php

Services / Suricata / Blocked Hosts

Interfaces
Global Settings
Updates
Alerts
Blocks
Files
Pass Lists
Suppress
Logs View
Logs Mgmt
SID Mgmt

Sync
IP Lists

Blocked Hosts Log View Settings

Save or Remove Hosts
Download
All blocked hosts will be saved

Clear
All blocked hosts will be cleared

Save Settings
Save
Save auto-refresh and view settings

Refresh
☒
Default is ON

500
Number of blocked entries to view. Default is 500

Last 500 Hosts Blocked by Suricata

Note: Only blocked IP addresses from Legacy Mode interfaces are shown! For inline IPS mode interfaces, dropped IP addresses are highlighted on the ALERTS tab.

| Blocked IP    | Block Date/Time     | Block Alert Description                | Block Rule GID:SID | Remove Block |
|---------------|---------------------|----------------------------------------|--------------------|--------------|
| 10.93.255.185 | 04/10/2026 05:47:14 | ET SCAN Potential SSH Scan             | 1:2001219          | ✖            |
|               | 04/09/2026 21:40:24 | Intent d'injecció de comandes detectat | 1:1000015          |              |
|               | 04/09/2026 19:00:13 | Intent de SQL Injection detectat       | 1:1000012          |              |
|               | 04/09/2026 17:16:30 | Intent d'accés a /etc/passwd           | 1:1000011          |              |

- LAN

Des d'un dispositiu situat dintre de la xarxa LAN, fem ping repetides vegades.

```

alumne@client3-danilluc:~$ ping 10.93.255.94
PING 10.93.255.94 (10.93.255.94) 56(84) bytes of data.
64 bytes from 10.93.255.94: icmp_seq=1 ttl=64 time=2.69 ms
^C
--- 10.93.255.94 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 2.689/2.689/2.689/0.000 ms
alumne@client3-danilluc:~$ ping 10.93.255.94
PING 10.93.255.94 (10.93.255.94) 56(84) bytes of data.
64 bytes from 10.93.255.94: icmp_seq=1 ttl=64 time=2.13 ms
^C
--- 10.93.255.94 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 2.132/2.132/2.132/0.000 ms
alumne@client3-danilluc:~$ ping 10.93.255.94
PING 10.93.255.94 (10.93.255.94) 56(84) bytes of data.
64 bytes from 10.93.255.94: icmp_seq=1 ttl=64 time=2.28 ms
^C
--- 10.93.255.94 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 2.279/2.279/2.279/0.000 ms
alumne@client3-danilluc:~$ ping 10.93.255.94
PING 10.93.255.94 (10.93.255.94) 56(84) bytes of data.
64 bytes from 10.93.255.94: icmp_seq=1 ttl=64 time=2.67 ms
64 bytes from 10.93.255.94: icmp_seq=2 ttl=64 time=2.13 ms
^C
--- 10.93.255.94 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1000ms
rtt min/avg/max/mdev = 2.125/2.395/2.665/0.270 ms

```

|                 |                 |                              |
|-----------------|-----------------|------------------------------|
| LAN             | 192.168.20.10:8 | Escaneig detectat a la xarxa |
| Apr 09 18:35:07 | 10.93.255.94:0  |                              |
| LAN             | 192.168.20.10:8 | Escaneig detectat a la xarxa |
| Apr 09 18:34:26 | 10.93.255.94:0  |                              |
| LAN             | 192.168.20.10:8 | Escaneig detectat a la xarxa |
| Apr 09 18:32:42 | 10.93.255.94:0  |                              |

Provo d'accedir a l'arxiu /etc/passwd des de la LAN.

```

alumne@srv-danilluc:~$ curl "http://192.168.20.100/?file=/etc/passwd"
<html>
<head><title>301 Moved Permanently</title></head>
<body>
<center><h1>301 Moved Permanently</h1></center>
<hr><center>nginx</center>
</body>
</html>
alumne@srv-danilluc:~$

```

#### Suricata Alerts

| Interface/Time  | Src/Dst Address     | Description                  |
|-----------------|---------------------|------------------------------|
| LAN             | 192.168.20.11:44466 | Intent d'accés a /etc/passwd |
| Apr 10 16:24:05 | 192.168.20.100:80   |                              |

Simulo un atac DDoS amb l'nmap.

alumne@client3-danilluc: ~

alumne@client3-danilluc:~\$ sudo nmap -sS -Pn -p 1-1000 --min-rate 1500 192.168.20.100

[sudo] password for alumne:  
Starting Nmap 7.80 ( https://nmap.org ) at 2026-04-09 18:19 CEST  
Nmap scan report for pfSense.home.arpa (192.168.20.100)  
Host is up (0.0021s latency).  
Not shown: 997 filtered ports  
PORT STATE SERVICE  
53/tcp open domain  
80/tcp open http  
443/tcp open https  
MAC Address: 08:00:27:25:F7:DF (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 6.37 seconds  
alumne@client3-danilluc:~\$

Last 250 Alert Entries. (Most recent entries are listed first)

| Date                | Action | Pri | Proto | Class        | Src           | SPort | Dst            | DPort | GID:SID   | Description        |
|---------------------|--------|-----|-------|--------------|---------------|-------|----------------|-------|-----------|--------------------|
| 04/09/2026 19:31:32 |        | 3   | TCP   | Not Assigned | 192.168.20.10 | 64351 | 192.168.20.100 | 929   | 1:1000006 | Atac DDOS detectat |
| 04/09/2026 19:31:23 |        | 3   | TCP   | Not Assigned | 192.168.20.10 | 64350 | 192.168.20.100 | 940   | 1:1000006 | Atac DDOS detectat |
| 04/09/2026 19:30:09 |        | 3   | TCP   | Not Assigned | 192.168.20.10 | 64350 | 192.168.20.100 | 85    | 1:1000006 | Atac DDOS detectat |

Atac de força bruta per SSH, repetint la connexió SSH moltes vegades.

alumne@srv-danilluc:~\$ ssh alumne@192.168.20.100  
^C  
alumne@srv-danilluc:~\$ ssh alumne@192.168.20.100  
^C  
alumne@srv-danilluc:~\$ ssh alumne@192.168.20.100  
^C  
alumne@srv-danilluc:~\$ ssh alumne@192.168.20.100  
^C  
alumne@srv-danilluc:~\$ ssh alumne@192.168.20.100  
^C  
alumne@srv-danilluc:~\$ ssh alumne@192.168.20.100  
^C  
alumne@srv-danilluc:~\$ ssh alumne@192.168.20.100  
^C  
alumne@srv-danilluc:~\$ ssh alumne@192.168.20.100  
^C  
alumne@srv-danilluc:~\$

LAN

Apr 09 23:35:20

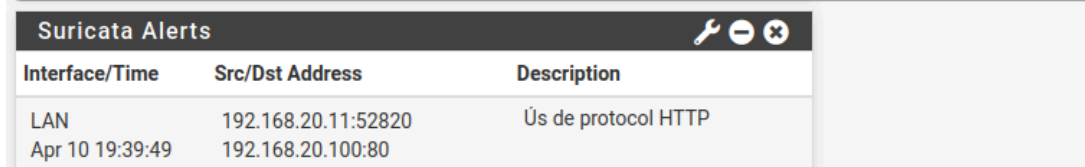
192.168.20.11:52692

192.168.20.100:22

Atac de força bruta SSH detectat

Prova enviant un usuari i contrasenya per HTTP.

```
alumne@srv-danilluc:~$ curl -X POST -d "user=admin&password=1234" http://192.168.20.100/login
<html>
<head><title>301 Moved Permanently</title></head>
<body>
<center><h1>301 Moved Permanently</h1></center>
<hr><center>nginx</center>
</body>
</html>
alumne@srv-danilluc:~$ _
```

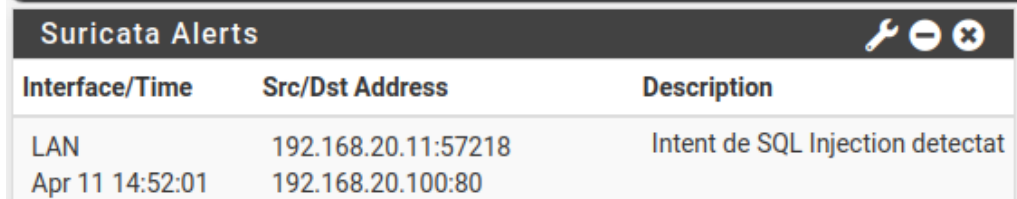


Suricata Alerts

| Interface/Time  | Src/Dst Address     | Description         |
|-----------------|---------------------|---------------------|
| LAN             | 192.168.20.11:52820 | Ús de protocol HTTP |
| Apr 10 19:39:49 | 192.168.20.100:80   |                     |

### SQL Injection.

```
alumne@srv-danilluc:~$ curl "http://192.168.20.100/?q=select+union"
<html>
<head><title>301 Moved Permanently</title></head>
<body>
<center><h1>301 Moved Permanently</h1></center>
<hr><center>nginx</center>
</body>
</html>
alumne@srv-danilluc:~$ _
```



Suricata Alerts

| Interface/Time  | Src/Dst Address     | Description                      |
|-----------------|---------------------|----------------------------------|
| LAN             | 192.168.20.11:57218 | Intent de SQL Injection detectat |
| Apr 11 14:52:01 | 192.168.20.100:80   |                                  |

Intentem descarregar un fitxer .exe, dona la alerta tant si existeix com si no.



```
alumni@client3-danilluc:~$ curl -v "http://192.168.20.100/test.exe"
* Trying 192.168.20.100:80...
* Connected to 192.168.20.100 (192.168.20.100) port 80 (#0)
> GET /test.exe HTTP/1.1
> Host: 192.168.20.100
> User-Agent: curl/7.81.0
> Accept: */*
>
* Mark bundle as not supporting multiuse
< HTTP/1.1 301 Moved Permanently
< Server: nginx
< Date: Mon, 13 Apr 2026 06:58:55 GMT
< Content-Type: text/html
< Content-Length: 162
< Connection: keep-alive
< Location: https://192.168.20.100/test.exe
< X-Frame-Options: SAMEORIGIN
<
<html>
<head><title>301 Moved Permanently</title></head>
<body>
<center><h1>301 Moved Permanently</h1></center>
<hr><center>nginx</center>
</body>
</html>
* Connection #0 to host 192.168.20.100 left intact
alumni@client3-danilluc:~$
```

| Interface/Time  | Src/Dst Address     | Description               |
|-----------------|---------------------|---------------------------|
| LAN             | 192.168.20.10:48446 | Intent de descàrrega .exe |
| Apr 13 06:58:55 | 192.168.20.100:80   | detectat                  |

## 2. Desenvolupament d'un pla de resposta a incidents

### - Fase de Preparació

En aquest apartat és tota la configuració que hem realitzat per tenir totes les eines actives i preparades. Hem configurat Suricata perquè actuï com a IPS sobre les amenaces que trobi, també tenim eve.json que ens dona tota la informació que necessitem i un sistema que ens avisa amb un missatge quan apareix cap alerta.

### - Fase d'Identificació i Anàlisi

Una vegada rebem una notificació sobre una nova amenaça a qualsevol de les nostres xarxes, hem de fer el següent:

- Entrar al pfSense i consultar les alertes noves que han aparegut al Suricata.
- Una vegada dintre, mirem la prioritat que apareix al missatge de l'amenaça.
- Identifiquem quina IP té l'atacant i el protocol o port afectat per l'atac.

### - Fase de Contenció

Si tot ha funcionat correctament, el motor IPS de Suricata haurà bloquejat la IP. Si per qualsevol motiu no s'ha bloquejat, l'afegirem nosaltres manualment a la llista negra.

### - Fase d'Eliminació

Revisem els logs per obtenir més informació sobre l'objectiu de l'atac, intent d'accés a un fitxer crític, intent d'injecció de codi SQL...

En el cas que l'atac sigui des d'un ordinador de la LAN, el primer que faríem seria aïllar-la completament de la xarxa. Seguidament, dintre de la màquina llençaríem un escaneig per

trobar la infecció de l'equip per eliminar-la i posteriorment mirar la raó per la qual s'ha infectat fins a arribar de saber qui ha estat amb l'ajuda dels logs.

- Fase de Recuperació

Ara comprovem que tots els serveis i ports estan actius i funcionant correctament sense perill. Si parlem d'un atac des de la xarxa interna, una vegada ens assegurem que el dispositiu atacant ja no està infectat, el tornem a deixar preparat per funcionar a la xarxa i eliminem la IP de la llista de bloquejos. Si es tracta d'un IP externa que no ens aporta res, la deixem bloquejada perquè no torni a intentar cap atac.

- Fase de Millora

Finalment, quan ja està tot solucionat i funcionant com sempre, toca ajustar o corregir les regles perquè no torni a passar cap atac d'aquell tipus o crear una nova regla que s'encarregui d'això. Depèn molt segons el motiu i si han aconseguit superar els nostres sistemes de seguretat.

### **3. Anàlisi i millora de la resposta a situacions crítiques**

- Anàlisi Profund

Quan tot ha tornat a la normalitat i s'ha solucionat la amenaça que hi havia, el següent pas es realitzar un anàlisi exhaustiu de les alertes, consultant els logs i tots els detalls per extreure la màxima informació possible.

Obtenim quin tipus d'atac han intentat realitzar, que han intentat fer i si han obtingut alguna informació delicada sobre els nostres equips o xarxes.

- Precisió de les Regles

Potser després d'un atac ens adonem que la regla que ha previngut l'atac ha tardat massa en activar-se perquè era massa permissiva o dèbil, si ens han fet un atac de força bruta i teniem a la regla 20 intents, a lo millor caldria baixar els intents a 5.

També assegurar-nos que la regla durant l'atac no ha afectat a màquines legítimes que estaven accedint al mateix lloc que l'atacant.

- Efectivitat de la comunicació

Comprovem si la notificació ens ha arribat just quan s'ha detectat l'amenaça i si el missatge era molt genèric i sense especificar o si pel contrari ens donava bona informació.

Ens assegurem que ens arribin les alertes de nivell alt i no avisos sense importància.

## **Configuració de Sistemes Complementaris**

### **1. Integració amb sistemes de firewall i antivirus**

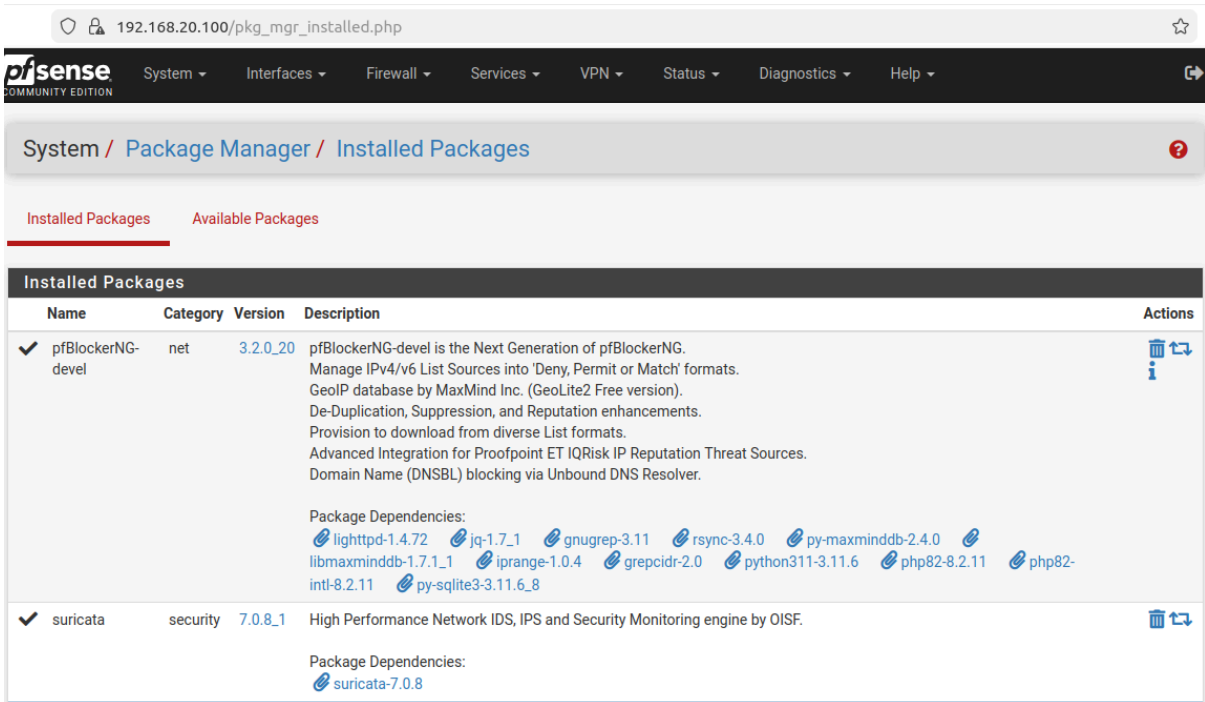
- pfBlockerNG

Volem aplicar una capa més de seguretat que bloqueja dominis malware i phishing mitjançant la reputació de la IP i filtratge DNS.

Anem al pfSense, prenem 8 per accedir a la consola i introduïm la següent comanda per instal·lar el paquet de pfBlockerNG (a la captura ja es troba instal·lat).

```
[12.7.2-RELEASE][root@pfSense.home.arpa]/root: pkg install -y pfSense-pkg-pfBlockerNG-devel
Updating pfSense-core repository catalogue...
Fetching meta.conf: 0%
Fetching packagesite.pkg: 0%
pfSense-core repository is up to date.
Updating pfSense repository catalogue...
Fetching meta.conf: 0%
Fetching packagesite.pkg: 0%
pfSense repository is up to date.
All repositories are up to date.
Checking integrity... done (0 conflicting)
The most recent versions of packages are already installed
```

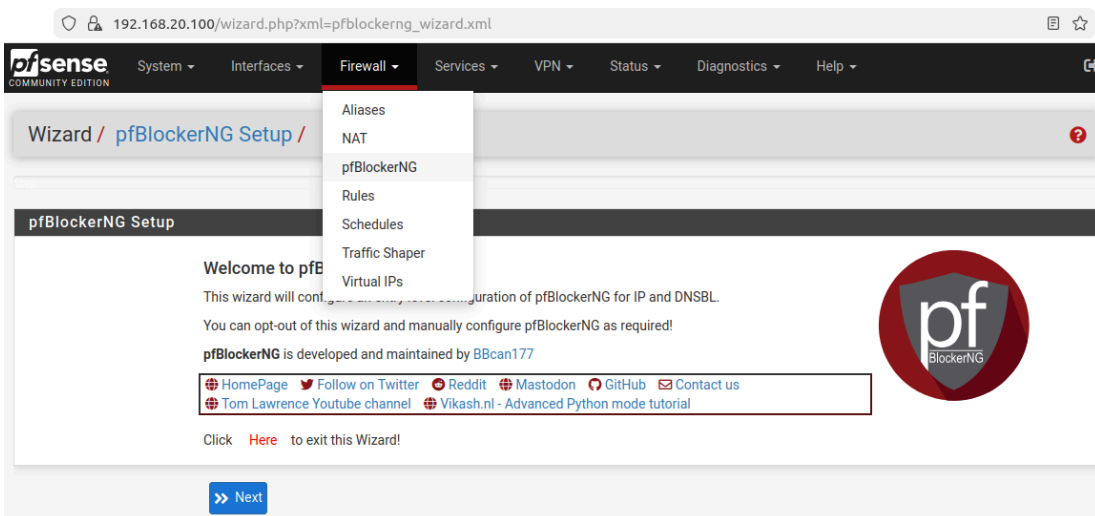
Ja ens apareix des del navegador.



The screenshot shows the pfSense web interface at 192.168.20.100/pkg\_mgr\_installed.php. The breadcrumb navigation is System / Package Manager / Installed Packages. There are two tabs: 'Installed Packages' (active) and 'Available Packages'. The 'Installed Packages' section contains a table with the following data:

| Name                | Category | Version  | Description                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | Actions                                                                                                                                                                     |
|---------------------|----------|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ✓ pfBlockerNG-devel | net      | 3.2.0_20 | pfBlockerNG-devel is the Next Generation of pfBlockerNG. Manage IPv4/v6 List Sources into 'Deny, Permit or Match' formats. GeoIP database by MaxMind Inc. (GeoLite2 Free version). De-Duplication, Suppression, and Reputation enhancements. Provision to download from diverse List formats. Advanced Integration for Proofpoint ET IQRisk IP Reputation Threat Sources. Domain Name (DNSBL) blocking via Unbound DNS Resolver.<br><br>Package Dependencies:<br>lighttpd-1.4.72 jq-1.7.1 gnugrep-3.11 rsync-3.4.0 py-maxminddb-2.4.0 libmaxminddb-1.7.1.1 iprange-1.0.4 grep-2.0 python311-3.11.6 php82-8.2.11 php82-intl-8.2.11 py-sqlite3-3.11.6.8 |     |
| ✓ suricata          | security | 7.0.8_1  | High Performance Network IDS, IPS and Security Monitoring engine by OISF.<br><br>Package Dependencies:<br>suricata-7.0.8                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |   |

Entrem a Firewall → pfBlockerNG i fem Next per començar amb la configuració.



The screenshot shows the pfSense web interface at 192.168.20.100/wizard.php?xml=pfblockerng\_wizard.xml. The breadcrumb navigation is Wizard / pfBlockerNG Setup. The 'Firewall' menu is open, showing options: Aliases, NAT, pfBlockerNG, Rules, Schedules, Traffic Shaper, and Virtual IPs. The 'pfBlockerNG Setup' wizard is displayed with the following content:

Welcome to pfBlockerNG Setup

This wizard will configure the installation and configuration of pfBlockerNG for IP and DNSBL. You can opt-out of this wizard and manually configure pfBlockerNG as required!

pfBlockerNG is developed and maintained by BBcan177

HomePage Follow on Twitter Reddit Mastodon GitHub Contact us  
Tom Lawrence Youtube channel Vikash.nl - Advanced Python mode tutorial

Click [Here](#) to exit this Wizard!

[Next](#)

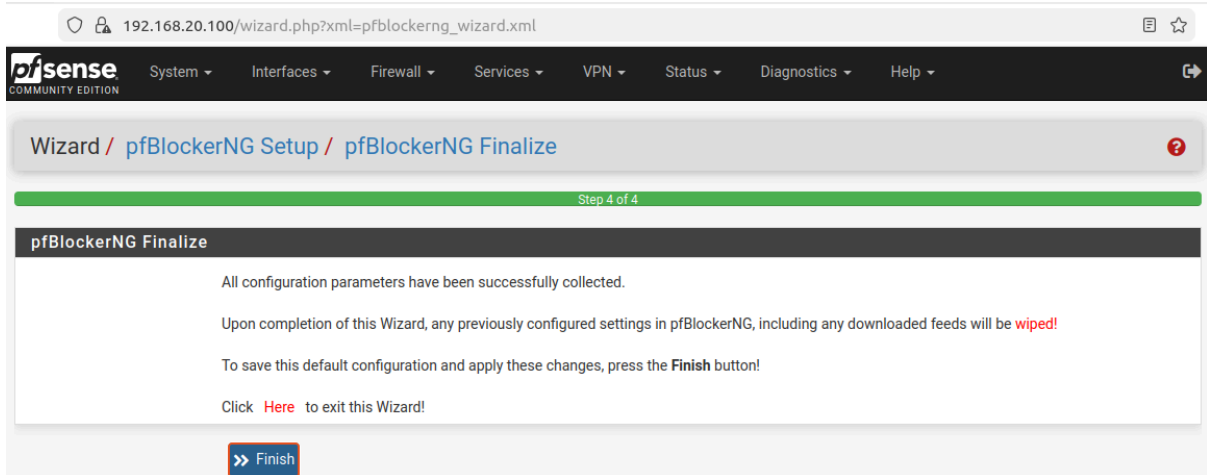
Inbound Firewall Interface és per on entren els paquets, WAN, bloquejarà atacants externs i Outbound per on surten, LAN, controlarà als usuaris de la xarxa interna.

The screenshot shows the pfSense web interface at 192.168.20.100. The breadcrumb trail is Wizard / pfBlockerNG Setup / pfBlockerNG IP Component Configuration. A progress bar indicates Step 2 of 4. The title is pfBlockerNG IP Component Configuration. Below the title, it says "On this screen the pfBlockerNG IP Category parameters will be set." There are two sections: "Select Inbound Firewall Interface" with a dropdown menu showing "WAN" and "LAN", and "Select Outbound Firewall Interface" with a dropdown menu showing "WAN" and "LAN". Below each dropdown is a text prompt: "Select the Inbound interface(s) you want to apply auto rules to:" and "Select the Outbound interface(s) you want to apply auto rules to:". At the bottom are two buttons: ">> Back" and ">> Next".

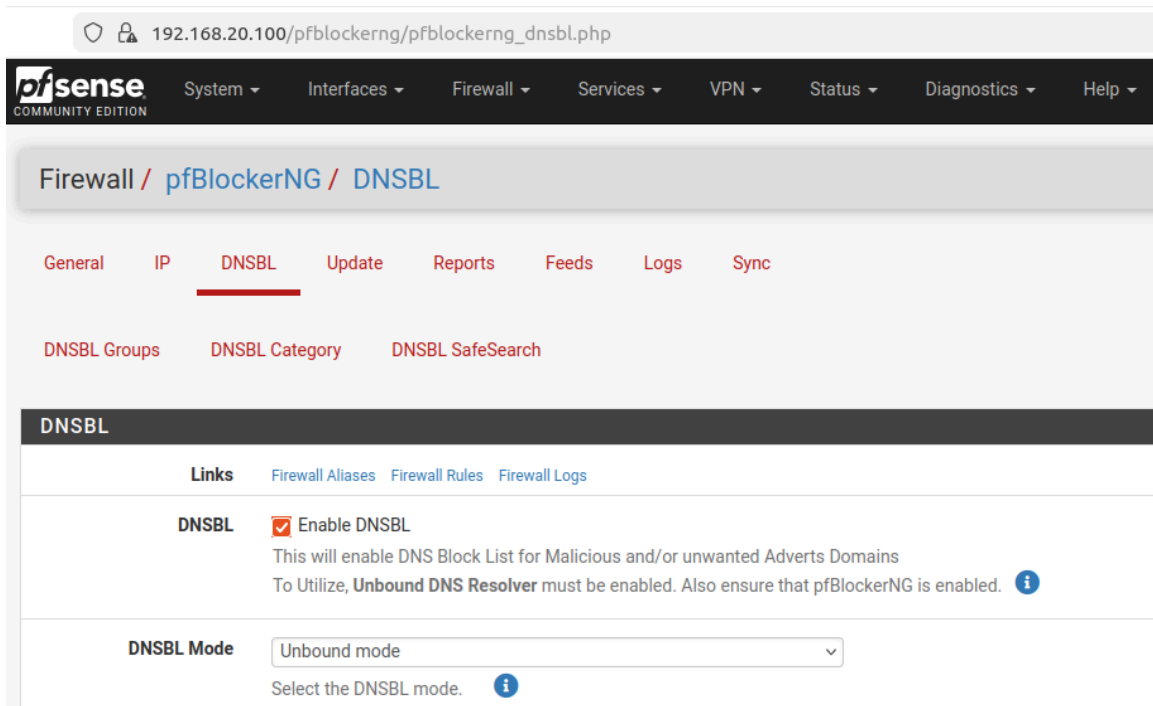
Deixem per defecte la configuració del DNSBL, aquesta serà la IP que afagarà el tràfic malèfic.

The screenshot shows the pfSense web interface at 192.168.20.100. The breadcrumb trail is Wizard / pfBlockerNG Setup / pfBlockerNG DNSBL Component Configuration. A progress bar indicates Step 3 of 4. The title is pfBlockerNG DNSBL Component Configuration. Below the title, it says "On this screen the pfBlockerNG DNSBL Category parameters will be set." There is a section titled "DNSBL Webserver Configuration" with the following fields: "VIP Address" (10.10.10.1), "Port" (8081), "SSL Port" (8443), "IPv6 DNSBL" (unchecked), and "DNSBL Whitelist" (checked). Below each field is a text prompt: "Local port upon which DNSBL Webserver will listen for connections. The default port is 8081. This can be left at its default unless a different port needs to be used." and "Local port upon which DNSBL Webserver will listen for connections. The default port is 8443. This can be left at its default unless a different port needs to be used." and "Enable DNSBL for IPv6 DNS Resolution filtering." and "Enable a default DNSBL Domain Whitelist. This list can be removed and/or modified following wizard installation." At the bottom are two buttons: ">> Back" and ">> Next".

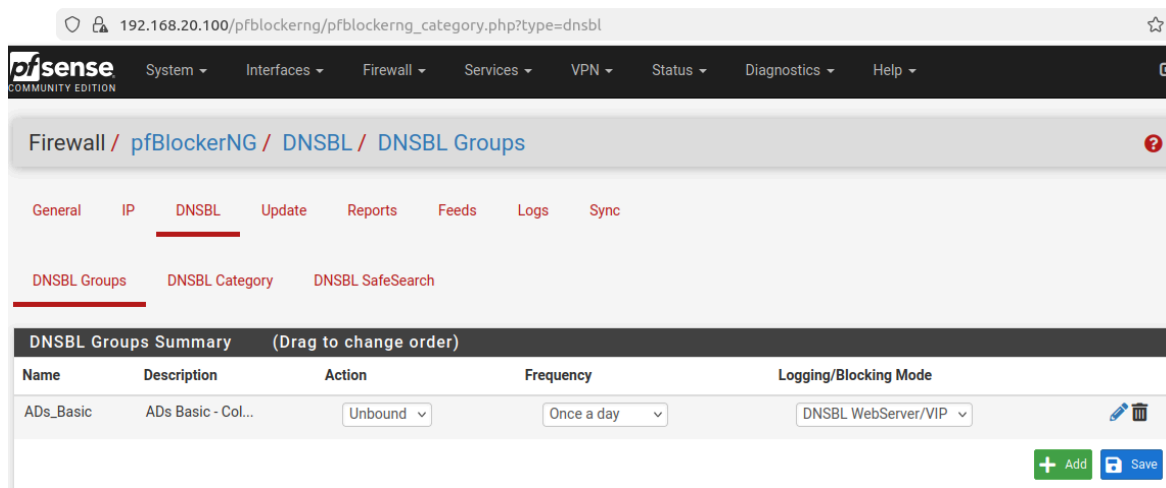
Fem Finish i esperem que acabi.



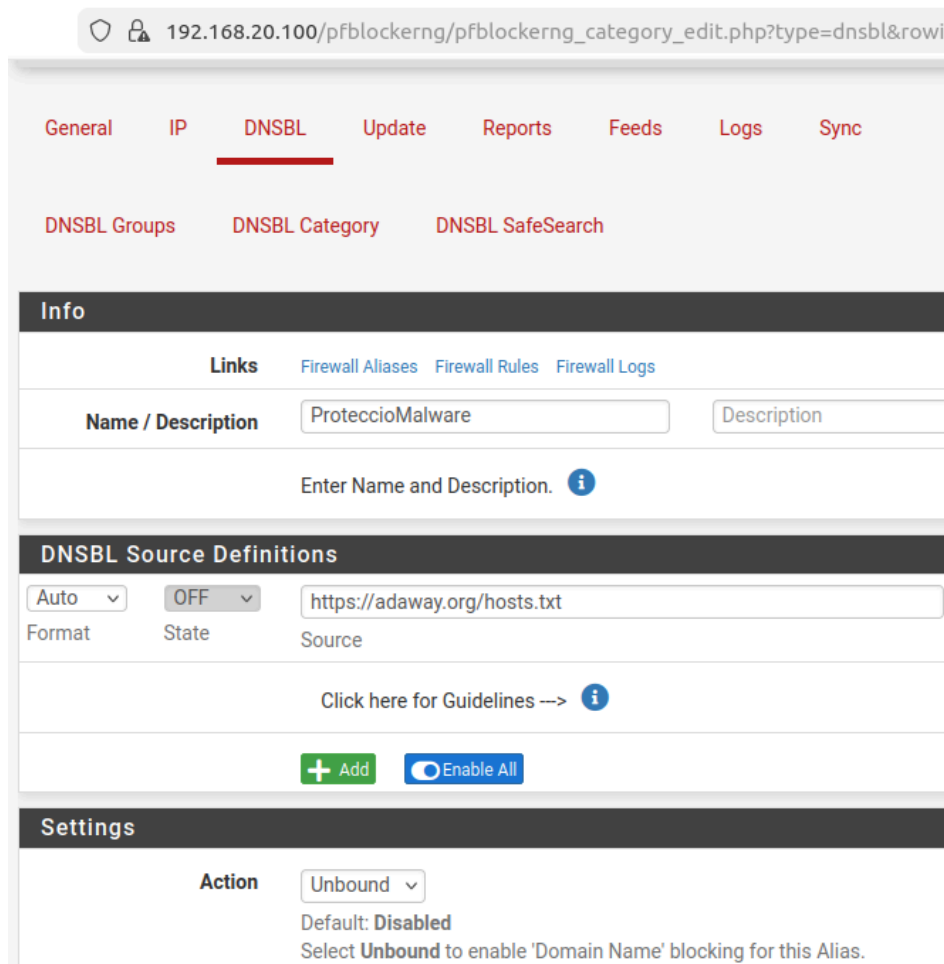
Ara ens toca configurar el DNSBL, que compleix la funció d'antivirus a la xarxa basat en blacklist. Ens assegurem que estigui activat i amb l'unbound mode.



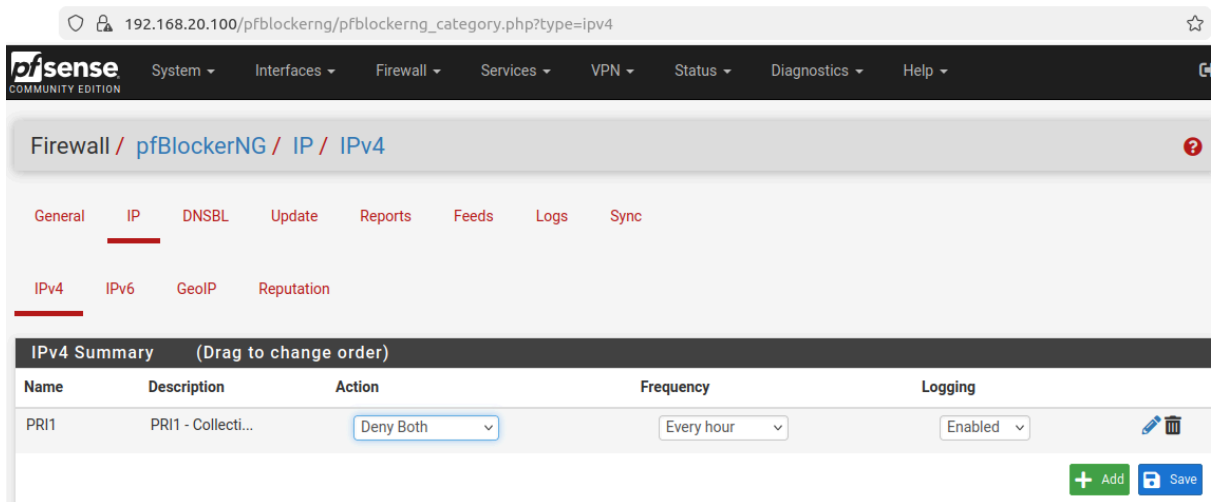
Ens movem a DNSBL Groups i afegim una llista nova.



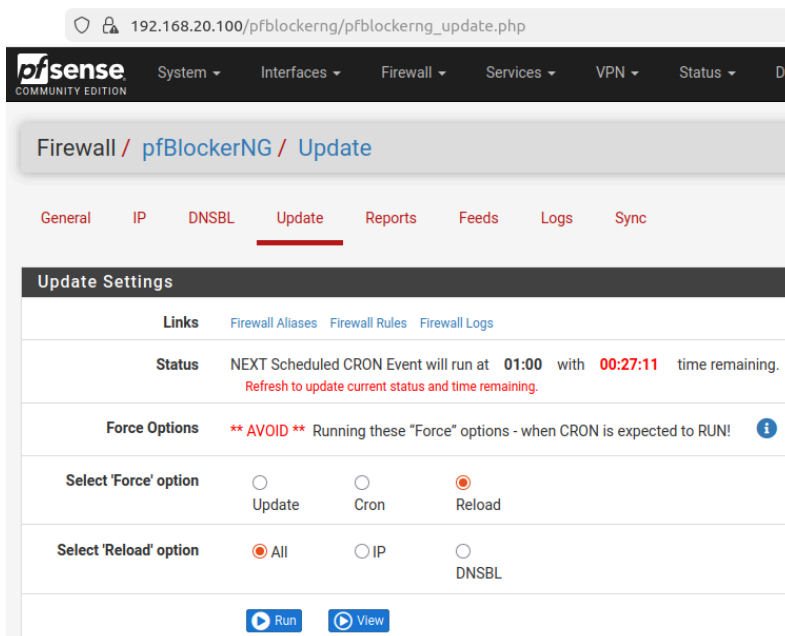
Li donem un nom, inserim el link d'un arxiu amb una llista de dominis fraudulents i Unbound a action perquè bloquegi el dominis.



Una altra opció que ofereix és la de bloquejar IP's, entrem a IP → IPv4 i editem l'acció de PRI1 perquè bloquegi entrada i sortida de les llistes afegides.



Finalment anem a la pestanya Update, escollim Reload i All i fem Run per aplicar els canvis realitzats.



Quan finalitza ens retorna un log on es veu tot el que ha aplicat, les llistes de IP's i de dominis

```

===[ Deny List IP Counts ]=====
17081 total
14999 /var/db/pfblockerng/deny/CINS_army_v4.txt
1612 /var/db/pfblockerng/deny/ET_Block_v4.txt
449 /var/db/pfblockerng/deny/ET_Comp_v4.txt
11 /var/db/pfblockerng/deny/Spamhaus_Drop_v4.txt
8 /var/db/pfblockerng/deny/ISC_Block_v4.txt
1 /var/db/pfblockerng/deny/Abuse_SSLBL_v4.txt
1 /var/db/pfblockerng/deny/Abuse_Feodo_C2_v4.txt

===== [ Empty Lists w/127.1.7.7 ] =====

Abuse_SSLBL_v4.txt

===== [ IPv4/6 Last Updated List Summary ] =====

Jan 3 2025 Abuse_SSLBL_v4
Mar 12 07:15 Abuse_Feodo_C2_v4
Apr 9 04:30 ET_Block_v4
Apr 9 20:30 ET_Comp_v4
Apr 10 12:34 CINS_army_v4
Apr 10 13:35 Spamhaus_Drop_v4
Apr 10 13:59 ISC_Block_v4

Database Sanity check [ PASSED ]

===[ DNSBL Process ]=====
Loading DNSBL Statistics... completed
Missing DNSBL stats and/or Unbound DNSBL files - Rebuilding

Loading DNSBL SafeSearch... disabled
Loading DNSBL Whitelist... completed

[ StevenBlack_Ads ] Downloading update .. 200 OK.
Whitelist: localhost.localdomain

-----
Orig. Unique # Dups # White # TOPIM Final
-----
92277 92277 0 1 0 92276
-----

[ adaway ] Downloading update [ 04/14/26 02:10:25 ] .. 200 OK.
-----
Orig. Unique # Dups # White # TOPIM Final
-----
6540 6540 6524 0 0 16
-----

Saving DNSBL statistics... completed

```

Des d'algun client intentem accedir a qualsevol de les pàgines web que estan a la llista i comprovem que ens bloqueja l'accés.

ifSense.home.arpa - Fire x Site blocked via DNSBL x Site blocked via DNSBL x +

→ ↻ Not Secure http://bypass.ad-stir.com

This website **bypass.ad-stir.com** has been blocked by the Network Administrator!

| Referer                    | Client        | Type  | Group           | Evaluated Domain   | Feed            |
|----------------------------|---------------|-------|-----------------|--------------------|-----------------|
| http://bypass.ad-stir.com/ | 192.168.20.10 | DNSBL | DNSBL_Ads_Basic | bypass.ad-stir.com | StevenBlack_Ads |

Powered by: **pfBlockerNG DNSBL** [pfBlockerNG.com](https://pfblocker.org/)

---

Sense.home.arpa - Fire x Site blocked via DNSBL x Site blocked via DNSBL x +

→ ↻ Not Secure http://www.uvunul.com

This website **www.uvunul.com** has been blocked by the Network Administrator!

| Referer | Client        | Type  | Group           | Evaluated Domain | Feed            |
|---------|---------------|-------|-----------------|------------------|-----------------|
| Unknown | 192.168.20.10 | DNSBL | DNSBL_Ads_Basic | www.uvunul.com   | StevenBlack_Ads |

Powered by: **pfBlockerNG DNSBL** [pfBlockerNG.com](https://pfblocker.org/)

---

Sense.home.arpa - Fire x Site blocked via DNSBL x Site blocked via DNSBL x Site blocked via DNSBL x +

→ ↻ Not Secure http://app.pulsatehq.com

This website **app.pulsatehq.com** has been blocked by the Network Administrator!

| Referer | Client        | Type  | Group           | Evaluated Domain  | Feed            |
|---------|---------------|-------|-----------------|-------------------|-----------------|
| Unknown | 192.168.20.10 | DNSBL | DNSBL_Ads_Basic | app.pulsatehq.com | StevenBlack_Ads |

Powered by: **pfBlockerNG DNSBL** [pfBlockerNG.com](https://pfblocker.org/)

---

Sense.home.arpa - Fire x Site blocked via DNSBL x +

→ ↻ Not Secure http://adservice.google.com

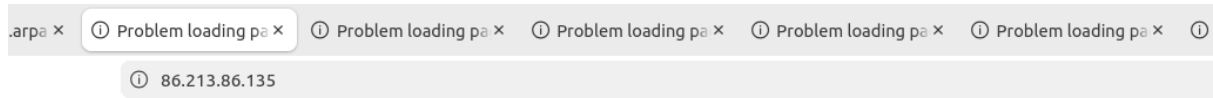
This website **adservice.google.com** has been blocked by the Network Administrator!

| Referer | Client        | Type  | Group           | Evaluated Domain     | Feed            |
|---------|---------------|-------|-----------------|----------------------|-----------------|
| Unknown | 192.168.20.10 | DNSBL | DNSBL_Ads_Basic | adservice.google.com | StevenBlack_Ads |

Powered by: **pfBlockerNG DNSBL** [pfBlockerNG.com](https://pfblocker.org/)



També provem amb IP's, per exemple, la 86.213.86.135, la 114.111.54.188 i la 50.16.16.211.



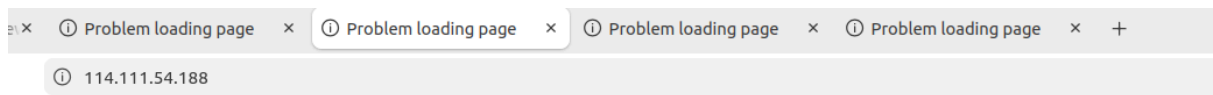
## Unable to connect

Firefox can't establish a connection to the server at 86.213.86.135.

- The site could be temporarily unavailable or too busy. Try again in a few moments.
- If you are unable to load any pages, check your computer's network connection.
- If your computer or network is protected by a firewall or proxy, make sure that Firefox is permitted to access the web.

Try Again

|                                                                                                                                                           |     |                             |       |                                |  |                   |     |                               |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------|-----|-----------------------------|-------|--------------------------------|--|-------------------|-----|-------------------------------|
| Apr 14 06:31:02 [1]                                                                                                                                       | LAN | pfB_PRI1_v4<br>(1770009481) | TCP-S | 192.168.20.10:45032<br>Unknown |  | 86.213.86.135:443 | Unk | CINS_army_v4<br>86.213.86.135 |
| Apr 14 04:36:10,1770009481,em1,LAN,block,4,6,TCP-S,192.168.20.10,86.213.86.135,35404,80,out,Unk,pfB_PRI1_v4,86.213.86.135,CINS_army_v4,lfn-bor-1-626-135  |     |                             |       |                                |  |                   |     |                               |
| Apr 14 04:36:10,1770009481,em1,LAN,block,4,6,TCP-S,192.168.20.10,86.213.86.135,35404,80,out,Unk,pfB_PRI1_v4,86.213.86.135,CINS_army_v4,lfn-bor-1-626-135  |     |                             |       |                                |  |                   |     |                               |
| Apr 14 04:36:10,1770009481,em1,LAN,block,4,6,TCP-S,192.168.20.10,86.213.86.135,35404,80,out,Unk,pfB_PRI1_v4,86.213.86.135,CINS_army_v4,lfn-bor-1-626-135  |     |                             |       |                                |  |                   |     |                               |
| Apr 14 04:36:15,1770009481,em1,LAN,block,4,6,TCP-S,192.168.20.10,86.213.86.135,45748,443,out,Unk,pfB_PRI1_v4,86.213.86.135,CINS_army_v4,lfn-bor-1-626-135 |     |                             |       |                                |  |                   |     |                               |
| Apr 14 04:36:15,1770009481,em1,LAN,block,4,6,TCP-S,192.168.20.10,86.213.86.135,45748,443,out,Unk,pfB_PRI1_v4,86.213.86.135,CINS_army_v4,lfn-bor-1-626-135 |     |                             |       |                                |  |                   |     |                               |



## Unable to connect

Firefox can't establish a connection to the server at 114.111.54.188.

- The site could be temporarily unavailable or too busy. Try again in a few moments.
- If you are unable to load any pages, check your computer's network connection.
- If your computer or network is protected by a firewall or proxy, make sure that Firefox is permitted to access the web.

Try Again

|                     |     |                             |       |                                |                                                                                                                                                                     |                               |                                                                                     |     |                              |
|---------------------|-----|-----------------------------|-------|--------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------|-------------------------------------------------------------------------------------|-----|------------------------------|
| Apr 14 05:58:02 [1] | LAN | pfB_PRI1_v4<br>(1770009481) | TCP-S | 192.168.20.10:60162<br>Unknown |   | 114.111.54.188:443<br>Unknown |  | Unk | ET_Comp_v4<br>114.111.54.188 |
| Apr 14 05:58:02 [2] | LAN | pfB_PRI1_v4<br>(1770009481) | TCP-S | 192.168.20.10:49014<br>Unknown |   | 114.111.54.188:80<br>Unknown  |  | Unk | ET_Comp_v4<br>114.111.54.188 |

Apr 14 05:58:02,1770009481,em1,LAN,block,4,6,TCP-S,192.168.20.10,114.111.54.188,49014,80,out,Unk,pfB\_PRI1\_v4,114.111.54.188,ET\_Comp\_v4,Unknown,Unknown,nul  
 Apr 14 05:58:02,1770009481,em1,LAN,block,4,6,TCP-S,192.168.20.10,114.111.54.188,49014,80,out,Unk,pfB\_PRI1\_v4,114.111.54.188,ET\_Comp\_v4,Unknown,Unknown,nul  
 Apr 14 05:58:02,1770009481,em1,LAN,block,4,6,TCP-S,192.168.20.10,114.111.54.188,49014,80,out,Unk,pfB\_PRI1\_v4,114.111.54.188,ET\_Comp\_v4,Unknown,Unknown,nul  
 Apr 14 05:58:02,1770009481,em1,LAN,block,4,6,TCP-S,192.168.20.10,114.111.54.188,60162,443,out,Unk,pfB\_PRI1\_v4,114.111.54.188,ET\_Comp\_v4,Unknown,Unknown,nul  
 Apr 14 05:58:02,1770009481,em1,LAN,block,4,6,TCP-S,192.168.20.10,114.111.54.188,60162,443,out,Unk,pfB\_PRI1\_v4,114.111.54.188,ET\_Comp\_v4,Unknown,Unknown,nul

⓪ Problem loading page
⓪ Problem loading page
⓪ Problem loading page
+

⓪ 50.16.16.211

## Unable to connect

Firefox can't establish a connection to the server at 50.16.16.211.

- The site could be temporarily unavailable or too busy. Try again in a few moments.
- If you are unable to load any pages, check your computer's network connection.
- If your computer or network is protected by a firewall or proxy, make sure that Firefox is permitted to access the web.

Try Again

|                                                                                                                                                             |     |                             |      |                          |                                                                                                                                                                         |                                                          |                                                                                      |     |                                     |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|-----------------------------|------|--------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------|--------------------------------------------------------------------------------------|-----|-------------------------------------|
| Apr 14 06:31:01                                                                                                                                             | LAN | pfB_PRI1_v4<br>(1770009481) | ICMP | 192.168.20.10<br>Unknown |   | 50.16.16.211<br>ec2-50-16-16-211.compute-1.amazonaws.com |  | Unk | Abuse_Feodo_C2_v...<br>50.16.16.211 |
| Apr 14 07:05:57,1770009481,em1,LAN,block,4,6,TCP-S,192.168.20.10,50.16.16.211,39324,80,out,Unk,pfB_PRI1_v4,50.16.16.211,Abuse_Feodo_C2_v4,ec2-50-16-16-211  |     |                             |      |                          |                                                                                                                                                                         |                                                          |                                                                                      |     |                                     |
| Apr 14 07:05:57,1770009481,em1,LAN,block,4,6,TCP-S,192.168.20.10,50.16.16.211,39324,80,out,Unk,pfB_PRI1_v4,50.16.16.211,Abuse_Feodo_C2_v4,ec2-50-16-16-211  |     |                             |      |                          |                                                                                                                                                                         |                                                          |                                                                                      |     |                                     |
| Apr 14 07:05:57,1770009481,em1,LAN,block,4,6,TCP-S,192.168.20.10,50.16.16.211,39324,80,out,Unk,pfB_PRI1_v4,50.16.16.211,Abuse_Feodo_C2_v4,ec2-50-16-16-211  |     |                             |      |                          |                                                                                                                                                                         |                                                          |                                                                                      |     |                                     |
| Apr 14 07:05:57,1770009481,em1,LAN,block,4,6,TCP-S,192.168.20.10,50.16.16.211,33200,443,out,Unk,pfB_PRI1_v4,50.16.16.211,Abuse_Feodo_C2_v4,ec2-50-16-16-211 |     |                             |      |                          |                                                                                                                                                                         |                                                          |                                                                                      |     |                                     |
| Apr 14 07:05:57,1770009481,em1,LAN,block,4,6,TCP-S,192.168.20.10,50.16.16.211,33200,443,out,Unk,pfB_PRI1_v4,50.16.16.211,Abuse_Feodo_C2_v4,ec2-50-16-16-211 |     |                             |      |                          |                                                                                                                                                                         |                                                          |                                                                                      |     |                                     |

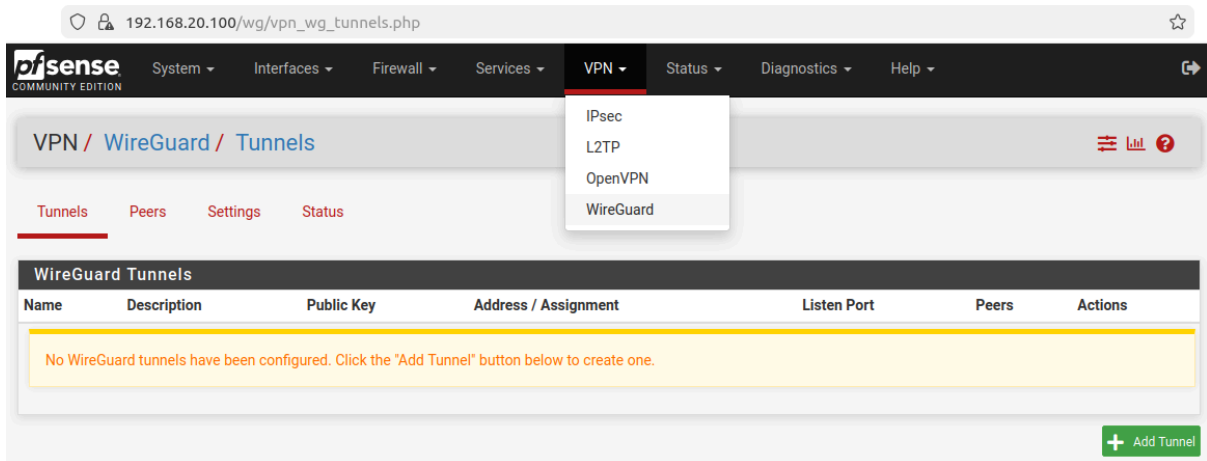
## 2. Configuració de connexions segures (VPN) i altres capes de seguretat

### - WireGuard

Hem implementar una capa d'accés remot segur amb VPN, d'aquesta manera establim un accés xifrat completament amb un tunel pels usuaris que es connecten remotament.

```
[2.7.2-RELEASE][root@pfSense.home.arpal/root]: pkg install pfSense-pkg-wireguard
Updating pfSense-core repository catalogue...
Fetching meta.conf: 0%
Fetching packagesite.pkg: 0%
pfSense-core repository is up to date.
Updating pfSense repository catalogue...
Fetching meta.conf: 0%
Fetching packagesite.pkg: 0%
pfSense repository is up to date.
All repositories are up to date.
Checking integrity... done (0 conflicting)
The most recent versions of packages are already installed
```

Accedim a VPN → Wireguard i afegim un túnel nou.



Configurem el port, la IP i generem unq parella de claus.

Clau Pública: IuI91W+9ROqq14gvLJzl7dcOjGhr7QeEenSEQVCQDzs=

Tunnels Peers Settings Status

Tunnel Configuration (tun\_wg0)

Enable ☒ Enable Tunnel  
Note: Tunnel must be enabled in order to be assigned to a pfSense interface.

Description   
Description for administrative reference (not parsed).

Listen Port   
Port used by this tunnel to communicate with peers.

Interface Keys     
Private key for this tunnel. (Required) Public key for this tunnel. (Copy) New Keys

Interface Configuration (tun\_wg0)

Assignment [Interface Assignments](#)

Firewall Rules [WireGuard Interface Group](#)

Hint These interface addresses are only applicable for unassigned WireGuard tunnel interfaces.

Interface Addresses  /    
IPv4 or IPv6 address assigned to the tunnel interface. Description for administrative reference (not parsed).

Add Address

Guardem el túnel i fem click a Add Peer.

Peer Configuration

| Description                                                                          | Public key | Tunnel | Allowed IPs | Endpoint : Port | Actions |
|--------------------------------------------------------------------------------------|------------|--------|-------------|-----------------|---------|
| <input type="button" value="+ Add Peer"/> <input type="button" value="Save Tunnel"/> |            |        |             |                 |         |

Omplenem la configuració amb una descripció, la clau pública del túnel i a Allowed IPs inserim 0.0.0.0/0 per tenir accés a internet a través de la VPN.

192.168.20.100/wg/vpn\_wg\_peers\_edit.php?peer=0

### Peer Configuration

**Enable** ☒ Enable Peer  
Note: Uncheck this option to disable this peer without removing it from the list.

**Tunnel**   
WireGuard tunnel for this peer. ([Create a New Tunnel](#))

**Description**   
Peer description for administrative reference (not parsed).

**Dynamic Endpoint** ☒ Dynamic  
Note: Uncheck this option to assign an endpoint address and port for this peer.

**Keep Alive**   
Interval (in seconds) for Keep Alive packets sent to this peer. Default is empty (disabled).

**Public Key**   
WireGuard public key for this peer.

**Pre-shared Key**  [Generate](#)  
Optional pre-shared key for this tunnel. ([Copy](#)) New Pre-shared Key

### Address Configuration

**Hint** Allowed IP entries here will be transformed into proper subnet start boundaries prior to validating and saving. These entries must be unique between multiple peers on the same tunnel. Otherwise, traffic to the conflicting networks will only be routed to the last peer in the list.

**Allowed IPs**  /    
IPv4 or IPv6 subnet or host reachable via this peer. Description for administrative reference (not parsed).

**Add Allowed IP** [+ Add Allowed IP](#)

Creem una regla al firewall a la interfície de WireGuard que permeti la connexió pel port 51820 a la interfície WAN amb el protocol UDP.

192.168.20.100/firewall\_rules\_edit.php?if=WireGuard&after=-1

**pfSense** COMMUNITY EDITION

System ▾ Interfaces ▾ Firewall ▾ Services ▾ VPN ▾ Status ▾

## Firewall / Rules / Edit

### Edit Firewall Rule

**Action**   
Choose what to do with packets that match the criteria specified below. Hint: the difference between block and reject is that with reject, a packet (TCP F) whereas with block the packet is dropped silently. In either case, the original pa

**Disabled** ☐ Disable this rule  
Set this option to disable this rule without removing it from the list.

**Interface**   
Choose the interface from which packets must come to match this rule.

**Address Family**   
Select the Internet Protocol version this rule applies to.

**Protocol**   
Choose which IP protocol this rule should match.

Li especifiquem que el destí sigui la adreça de la interfície WAN i el port sigui el 51820, el del túnel de la VPN.

Source

**Source** ☐ Invert match Any Source Address /

[Display Advanced](#)

The **Source Port Range** for a connection is typically random and almost never equal to the destination port. In most cases this setting must remain at its default value, any.

Destination

**Destination** ☐ Invert match WAN address Destination Address /

**Destination Port Range** (other) 51820 (other) 51820

From Custom To Custom

Specify the destination port or port range for this rule. The "To" field may be left empty if only filtering a single port.

Regla ja aplicada i activa.

192.168.20.100/firewall\_rules.php?if=WireGuard

System Interfaces Firewall Services VPN Status Diagnostics Help

Firewall / Rules / WireGuard

The changes have been applied successfully. The firewall rules are now reloading in the background. [Monitor the filter reload progress.](#)

Floating WireGuard WAN LAN

Rules (Drag to Change Order)

|                          | States | Protocol | Source   | Port | Destination | Port        | Gateway | Queue | Schedule | Description | Actions                                            |
|--------------------------|--------|----------|----------|------|-------------|-------------|---------|-------|----------|-------------|----------------------------------------------------|
| <input type="checkbox"/> | ✓      | 0/0 B    | IPv4 UDP | *    | *           | WAN address | 51820   | *     | none     |             | <a href="#">Monitor the filter reload progress</a> |

Add Add Delete Toggle Copy Save Separator

Anem al Client i configurem l'arxiu de WireGuard per establir la connexió amb pfSense. Li assignem l'adreça que volem que tingui a la xarxa de la VPN, IP del servidor DNS dintre de la xarxa de la VPN, clau pública del túnel VPN, permetem totes les IPs i la IP del servidor per enviar la petició.

Crear un túnel nuevo

Nombre: pfSense

Clave pública: 8WrexON2I9EpbrKR3SdaKb6783SZRzrmBRi53KS+tmo=

**[Interface]**  
**PrivateKey** = 8GcNtkgotIGt6YYZOzz4XTanQ07O/Cy4qz5uQwFh30A=  
**Address** = 10.0.1.2/24  
**DNS** = 10.0.1.1

**[Peer]**  
**PublicKey** = luI91W+9ROqq14gvLJzl7dcOjGhr7QeEenSEQVCQDzs=  
**AllowedIPs** = 0.0.0.0/0  
**Endpoint** = 10.93.255.94:51820

☒ Block untunneled traffic (kill-switch)

Guardar Cancelar

Guardem i activem la connexió. Veiem que s'estan enviant i rebent paquets.

WireGuard (out of date)

Túneles Registro Hay una actualización disponible!

pfSense  
VPN

Interfaz: pfSense

Estado: Activo

Clave pública: 8WrexON2I9EpbrKR3SdaKb6783SZRzrmBRi53KS+tmo=

Puerto de escucha: 53489

Direcciones: 10.0.1.2/24

Servidores DNS: 10.0.1.1

Desactivar

Pares

Clave pública: luI91W+9ROqq14gvLJzl7dcOjGhr7QeEenSEQVCQDzs=

IPs permitidas: 0.0.0.0/0

Endpoint: 10.93.255.94:51820

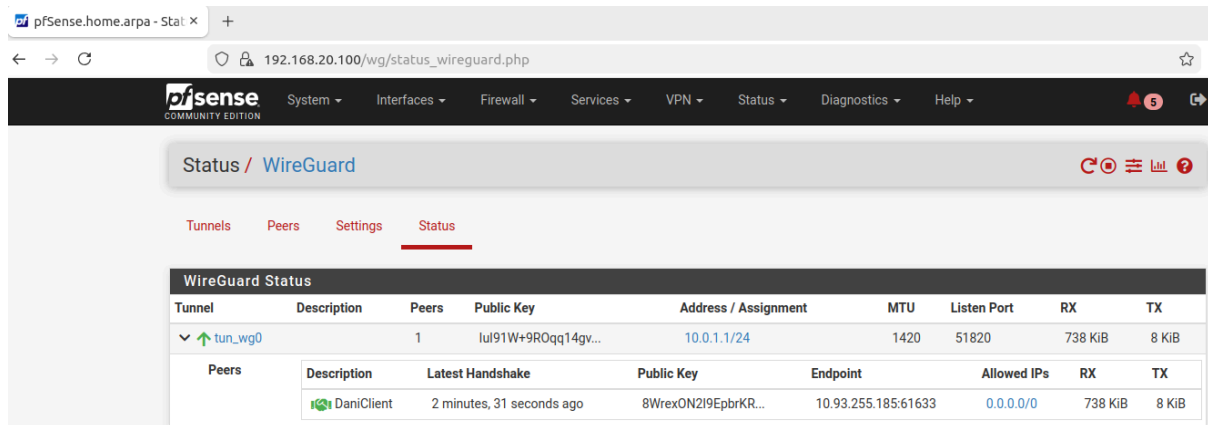
Último saludo: hace 11 segundos

Transferir: 7,26 KiB received, 720,95 KiB sent

Añadir túnel

Editar

A Status → WireGuard, també podem comprovar que hi ha connexió i transferència de paquets.



Fem un ping de prova per verificar que les màquines tenen connexió.

```
[2.7.2-RELEASE][root@pfSense.home.arpa]/root: ping 10.0.1.2
PING 10.0.1.2 (10.0.1.2): 56 data bytes
64 bytes from 10.0.1.2: icmp_seq=0 ttl=128 time=3.128 ms
64 bytes from 10.0.1.2: icmp_seq=1 ttl=128 time=4298.701 ms
64 bytes from 10.0.1.2: icmp_seq=2 ttl=128 time=6.284 ms
64 bytes from 10.0.1.2: icmp_seq=3 ttl=128 time=11.938 ms
64 bytes from 10.0.1.2: icmp_seq=4 ttl=128 time=10.123 ms
64 bytes from 10.0.1.2: icmp_seq=5 ttl=128 time=5.558 ms
64 bytes from 10.0.1.2: icmp_seq=6 ttl=128 time=3.263 ms
64 bytes from 10.0.1.2: icmp_seq=7 ttl=128 time=4.237 ms
^C
--- 10.0.1.2 ping statistics ---
8 packets transmitted, 8 packets received, 0.0% packet loss
round-trip min/avg/max/stddev = 3.128/542.904/4298.701/1419.561 ms
```

#### - GeoIP Blocking

Una altra capa de seguretat que veiem molt útil per afegir, és GeoIP, una funcionalitat extra de pfBlockerNG que ens dona la possibilitat de bloquejar peticions de continents dels que no esperem cap tràfic normal.

Accedim a Firewall → pfBlockerNG → IP → GeoIP.

192.168.20.100/pfblockerng/pfblockerng\_category.php?type=geoip

pfSense COMMUNITY EDITION

System Interfaces Firewall Services VPN Status Diagnostics Help

Firewall / pfBlockerNG / IP / GeoIP

General IP DNSBL Update Reports Feeds Logs Sync

IPv4 IPv6 **GeoIP** Reputation

**GeoIP Summary**

MaxMind now requires a License Key! Review the IP tab: MaxMind settings for more information.

| Name         | Description        | Action   | Logging |
|--------------|--------------------|----------|---------|
| Top Spammers | GeoIP Top Spammers | Disabled | Enabled |
| Africa       | GeoIP Africa       | Disabled | Enabled |
| Antarctica   | GeoIP Antarctica   | Disabled | Enabled |
| Asia         | GeoIP Asia         | Disabled | Enabled |

Pel nostre cas, hem marcat tots menys Europa.

192.168.20.100/pfblockerng/pfblockerng\_category.php?type=geoip

IPv4 IPv6 **GeoIP** Reputation

**GeoIP Summary**

MaxMind now requires a License Key! Review the IP tab: MaxMind settings for more information.

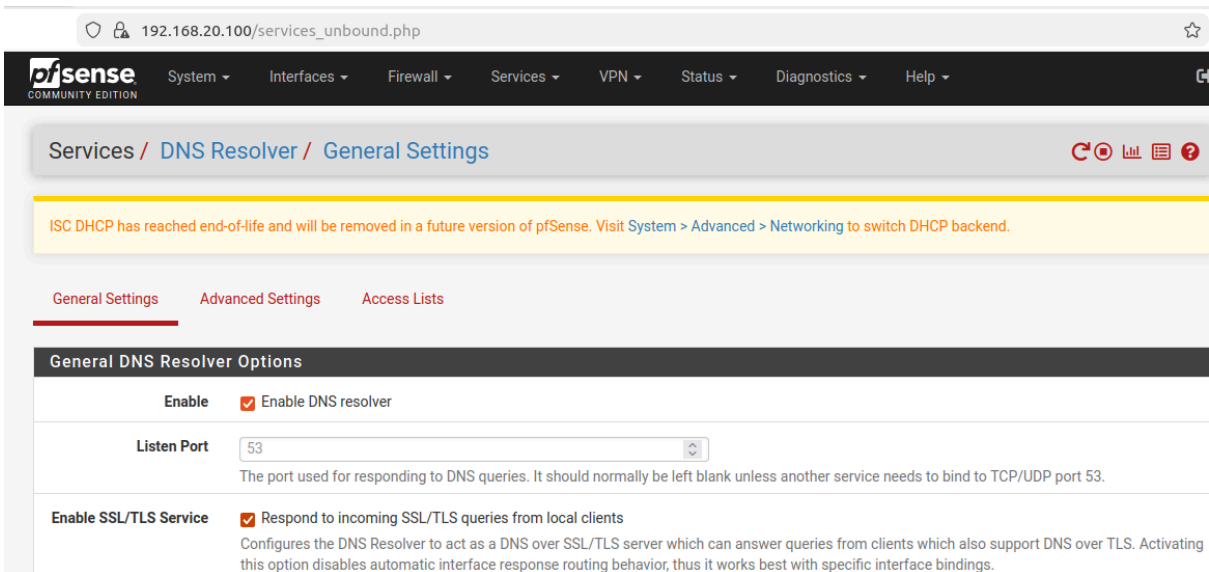
| Name                | Description         | Action    | Logging |
|---------------------|---------------------|-----------|---------|
| Top Spammers        | GeoIP Top Spammers  | Disabled  | Enabled |
| Africa              | GeoIP Africa        | Deny Both | Enabled |
| Antarctica          | GeoIP Antarctica    | Deny Both | Enabled |
| Asia                | GeoIP Asia          | Deny Both | Enabled |
| Europe              | GeoIP Europe        | Disabled  | Enabled |
| North America       | GeoIP North America | Deny Both | Enabled |
| Oceania             | GeoIP Oceania       | Deny Both | Enabled |
| South America       | GeoIP South America | Deny Both | Enabled |
| Proxy and Satellite | GeoIP Proxy and...  | Disabled  | Enabled |

Save

#### - Configuracions de Seguretat Extres

Dintre de la configuració de pfSense, hem activat que les consultes DNS viatjin per la xarxa xifrades.

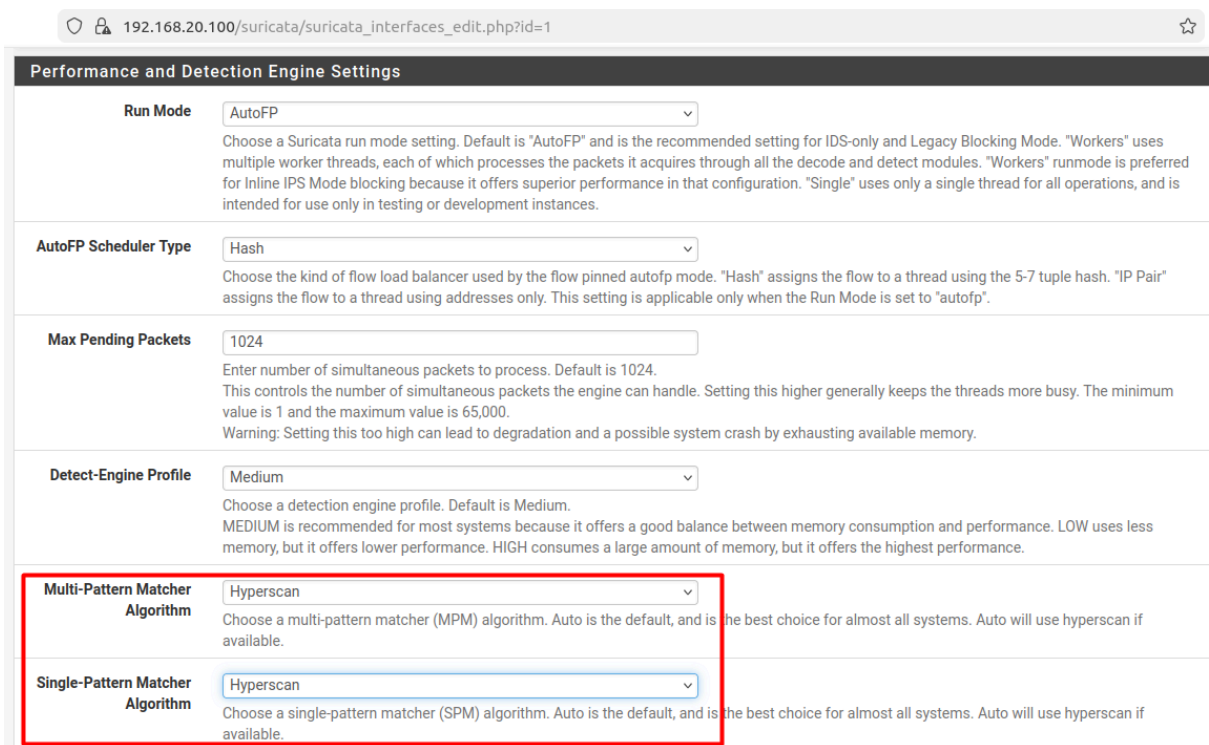




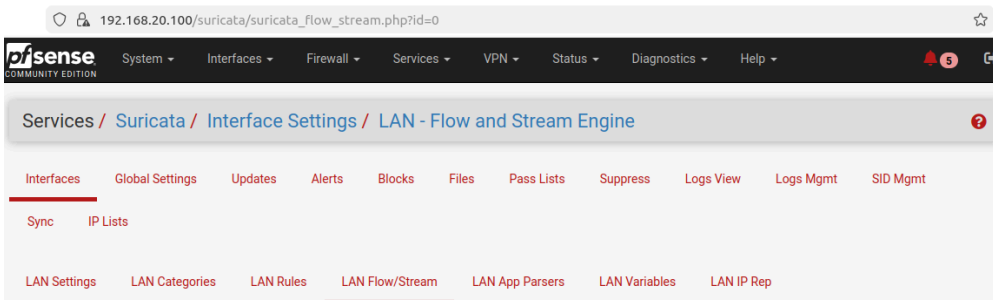
### 3. Optimització del rendiment del sistema IDS/IPS

Ens hem adonat que Suricata consumeix molta CPU i RAM si no es configura correctament, per això ara aplicarem opcions per millorar el seu rendiment.

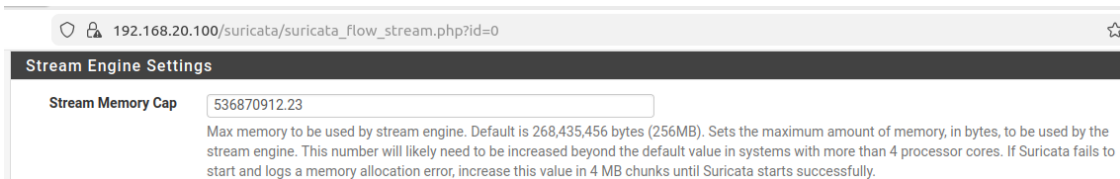
Per la primera configuració entrem a Services → Suricata → Interfaces → WAN i després LAN → Settings i busquem l'apartat Performance and Detection Engine Settings. Trobem dues opcions del motor de cerca, seleccionem a les dues Hyperscan perquè treballa amb instruccions de CPU avançades per realitzar el pattern matching en paral·lel, això redueix molt la latència i l'ús de cicles per paquet.



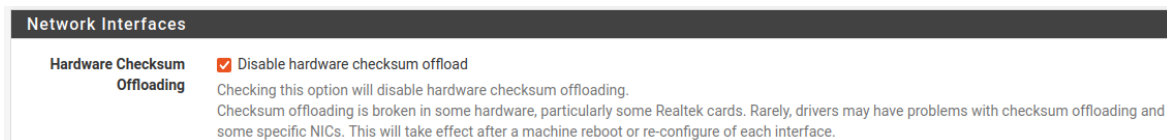
Canviem a l'apartat Flow/Stream.



Augmentem el límit de memòria RAM del motor a 512MB, ens assegurem que el sistema sempre té memòria disponible i el rendiment de la xarxa no es veu afectat negativament.



També al principi de tot vam deshabilitar el processament de checksums per hardware per evitar colls d'ampolla i errors al revisar els paquets.



Com volem optimitzar al màxim el rendiment de Suricata, hem pensat que a lo millor tenim paquets de regles que venen per defecte activats que pel nostre cas no ens serveixen i estan consumint recursos innecessàriament.

Hem investigat sobre la utilitat de cada Ruleset i aquests són els motius pels quals hem desactivat els següents paquets.

| Enabled                             | Ruleset: Default Rules |                                     |                     |
|-------------------------------------|------------------------|-------------------------------------|---------------------|
| <input checked="" type="checkbox"/> | app-layer-events.rules | <input type="checkbox"/>            | modbus-events.rules |
| <input checked="" type="checkbox"/> | decoder-events.rules   | <input type="checkbox"/>            | mqtt-events.rules   |
| <input checked="" type="checkbox"/> | dhcp-events.rules      | <input checked="" type="checkbox"/> | nfs-events.rules    |
| <input type="checkbox"/>            | dnp3-events.rules      | <input checked="" type="checkbox"/> | ntp-events.rules    |
| <input checked="" type="checkbox"/> | dns-events.rules       | <input type="checkbox"/>            | quic-events.rules   |
| <input checked="" type="checkbox"/> | files.rules            | <input checked="" type="checkbox"/> | rfb-events.rules    |
| <input checked="" type="checkbox"/> | ftp-events.rules       | <input checked="" type="checkbox"/> | smb-events.rules    |
| <input checked="" type="checkbox"/> | http-events.rules      | <input type="checkbox"/>            | smtp-events.rules   |
| <input checked="" type="checkbox"/> | http2-events.rules     | <input checked="" type="checkbox"/> | ssh-events.rules    |
| <input type="checkbox"/>            | ipsec-events.rules     | <input checked="" type="checkbox"/> | stream-events.rules |
| <input type="checkbox"/>            | kerberos-events.rules  | <input checked="" type="checkbox"/> | tls-events.rules    |

dnp3: És un protocol per xarxes elèctriques, no té utilitat per nosaltres.

ipsec: Protocol per crear xarxes privades virtuals, utilitzem WireGuard per la VPN.

kerberos: S'utilitza en dominis Windows d'Active Directory, no tenim cap controlador de domini.

modbus: Protocol de bus de comunicació per controladors lògics programables, no en tenim cap.

mqtt: Protocol per dispositius IOT, tampoc en tenim a la xarxa.

quic: Genera molts logs perquè Suricata no pot llegir els missatges xifrats de Google Chrome.

smtp: Protocol de correu, no tenim cap servidor de correu.